

TRƯỜNG ĐẠI HỌC VĂN HIẾN
KHOA CÔNG NGHỆ THÔNG TIN



TIỂU LUẬN CUỐI KỲ
HỌC PHẦN: BẢO MẬT IoT (INT4410)

**BẢO MẬT MQTT BẰNG MOSQUITTO VÀ PAHO
PYTHON**

Mã đề tài	12
Sinh viên	Mai Thị Thảo Vy
Mã số sinh viên	231A010112
Lớp học phần	253INT441001
Giảng viên	Hồ Nhật Minh

TP. HỒ CHÍ MINH, 2026

THÔNG TIN VÀ CAM KẾT NỘP BÀI

Tên đề tài	Bảo mật MQTT bằng Mosquitto và Paho Python
Mã đề tài	12
Sinh viên/ Nhóm	Mai Thị Thảo Vy – 231A010112
Repo GitHub	https://github.com/maivy111205/MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython
Bản báo cáo	231A010112_MaiThiThaoVy_DeTai12_TieuLuan_CuoiKy.docx 231A010112_MaiThiThaoVy_DeTai12_TieuLuan_CuoiKy.pdf
Sản phẩm chính	Code Python Publisher/ Subscriber, cấu hình Mosquitto Broker, file ACL, file cấu hình, log kiểm thử, sơ đồ mô hình MQTT
Ngày nộp	03/08/2026

Cam kết an toàn và học thuật

Em xin cam kết toàn bộ thử nghiệm được thực hiện trong môi trường cục bộ, thiết bị thuộc quyền sở hữu hoặc dữ liệu giả lập/được phép; không quét, khai thác hay thu thập dữ liệu từ hệ thống thật. Báo cáo, mã nguồn và minh chứng là kết quả làm việc của cá nhân; mọi nội dung kế thừa đều được trích dẫn rõ ràng. Repo không chứa secret, token, mật khẩu hoặc dữ liệu cá nhân thật.

Báo cáo có sử dụng công cụ Trí tuệ nhân tạo (AI) hỗ trợ kiểm tra ngôn ngữ và chỉnh sửa câu văn, hình ảnh. Cụ thể trong quá trình thực hiện đề tài, em có sử dụng công cụ Google Gemini để hỗ trợ cho các công việc: chỉnh sửa ngữ pháp, hỗ trợ cấu trúc dàn ý và tối ưu hóa câu văn báo cáo. Các công cụ này chỉ đóng vai trò hỗ trợ; toàn bộ ý tưởng cốt lõi, phương pháp nghiên cứu, quá trình phân tích dữ liệu và kết luận của công trình đều do em tự thực hiện và hoàn toàn chịu trách nhiệm về nội dung, kết quả thực hiện và các kết luận trong báo cáo.

TP. Hồ Chí Minh, ngày 03 tháng 08 năm 2026

Người cam kết

(Ký và ghi rõ họ tên)



Mai Thị Thảo Vy

PHẦN A — CHECKLIST TIẾN ĐỘ THỰC HIỆN ĐỀ TÀI

Tuần / Giai đoạn	Nội dung công việc thực hiện	Trạng thái	Minh chứng (Số trang / Commit)
Tuần 01	Tìm hiểu giao thức MQTT, khảo sát Mosquitto Broker, xác định phạm vi đề tài (Mã đề tài 12 - Hướng B) và hoàn thành Chương 1, Chương 2.	☒ Đạt	Trang 8–14 (commit Tuan01)
Tuần 02	Xây dựng phương pháp, thiết kế mô hình hệ thống (Chương 3); cài đặt Mosquitto Broker và viết script Python cơ bản.	☒ Đạt	Trang 15–18 (commit Tuan02)
Tuần 03	Triển khai chương trình Publisher/Subscriber, cấu hình bảo mật Username/Password, phân quyền ACL và chạy kịch bản kiểm thử (Chương 4).	☒ Đạt	Trang 19–27 (commit Tuan03)
Tuần 04	Kiểm tra tổng thể, định dạng báo cáo, chỉnh sửa nội dung, đồng bộ mã nguồn lên GitHub và chuẩn bị nộp bài.	☒ Đạt	Trang 28–32 (commit Tuan04)
Repo	Có README và commit Tuần 02; link mở được.	☒ Đạt	<u>GitHub Repo</u>

MỤC LỤC

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI	1
1.1. Bối cảnh và lý do chọn đề tài.....	1
1.2. Phát biểu vấn đề	1
1.3. Mục tiêu của đề tài	1
1.4. Đối tượng, phạm vi và giới hạn an toàn	2
1.5. Sản phẩm dự kiến và đóng góp	2
1.6. Cấu trúc báo cáo.....	3
Bảng đối chiếu mục tiêu và đầu ra.....	3
CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN	4
2.1. Kiến trúc, giao thức và công nghệ nền	4
2.2. Khái niệm bảo mật liên quan	5
2.3. Nội dung cần nhấn mạnh theo nhóm đề tài	5
2.4. Chuẩn, tài liệu và công cụ GitHub.....	5
2.5. Các công trình và giải pháp liên quan	6
2.6. Tiểu kết Chương 2	7
CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ	8
3.1. Phương pháp thực hiện.....	8
3.2. Mô hình/kiến trúc đề xuất	9
3.3. Môi trường, công cụ và dữ liệu	10
3.4. Quy trình triển khai	11
3.5. Tiêu chí đánh giá	12
CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ.....	14
4.1. Chuẩn bị môi trường.....	14
4.2. Thành phần sản phẩm	14
4.3. Kịch bản thử nghiệm/đánh giá.....	16
4.4. Kết quả	16
4.5 Script sinh báo cáo	22
4.6. Thảo luận và hạn chế	23
4.6.1. Kết quả so với mục tiêu	23
4.6.2. Hạn chế của hệ thống	23
CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT	25

5.1. Tài sản và dữ liệu.....	25
5.2. Mối đe dọa và lỗ hổng	25
5.3. Ma trận rủi ro.....	27
5.4. Biện pháp giảm thiểu	28
5.5. Rủi ro còn lại.....	28
CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN.....	30
6.1. Kết luận	30
6.2. Hạn chế.....	30
6.3. Hướng phát triển	30
TÀI LIỆU THAM KHẢO	32

DANH MỤC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích
1	IoT	Internet of Things (Mạng lưới thiết bị kết nối Internet)
2	MQTT	Message Queuing Telemetry Transport (Giao thức truyền tải dữ liệu nhẹ)
3	ACL	Access Control List (Danh sách điều khiển truy cập)
4	TLS/SSL	Transport Layer Security/ Secure Sockets Layer (Bảo mật lớp vận chuyển)
5	mTLS	Mutual Transport Layer Security (Xác thực hai chiều qua TLS)
6	JSON	JavaScript Object Notation (Định dạng dữ liệu cấu trúc dạng văn bản)
7	CIA	Confidentiality - Integrity - Availability (Bảo mật - Toàn vẹn - Sẵn sàng)
8	MITM	Man In The Middle (Tấn công đứng giữa)
9	DoS/DDoS	Denial of Service/ Distributed Denial of Service (Tấn công từ chối dịch vụ)

DANH MỤC HÌNH ẢNH

Hình 2.1: Mô hình kiến trúc hệ thống MQTT Publish/ Subscribe và ranh giới tin cậy (Trust Boundary)	4
Hình 3.1: Quy trình thực hiện đề tài bảo mật giao thức MQTT sử dụng Mosquitto Broker và Paho Python.....	8
Hình 3.2: Mô hình hệ thống MQTT Publish/Subscribe sử dụng Mosquitto Broker	9
Hình 4.1: Môi trường triển khai Mosquitto Broker và Python đang hoạt động trên hệ thống (Minh họa giao diện dòng lệnh khởi chạy Broker thành công trên Windows).	14
Hình 4.2: Tạo file password.txt chứa tài khoản sensor và dashboard	17
Hình 4.3: Nội dung file mosquitto.conf	17
Hình 4.4: Nội dung file aclfile.txt.....	17
Hình 4.5: Mosquitto Broker khởi động thành công và lắng nghe trên cổng 1883.	18
Hình 4.6: Subscriber kết nối thành công và đăng ký Topic iot/sensor/temp.....	18
Hình 4.7: Publisher gửi dữ liệu JSON lên Topic iot/sensor/temp thành công	19
Hình 4.8: Giao diện nhận tin và nội dung file log	19
Hình 4.9: Kết quả kiểm tra đăng nhập với mật khẩu sai.....	20
Hình 4.10: Kết quả kiểm tra Publish bị từ chối do sai quyền ACL.....	20
Hình 4.11: Kết quả kiểm tra Subscribe bị từ chối do sai quyền ACL.....	21

DANH MỤC BẢNG

Bảng 3.1: Môi trường triển khai và công cụ hệ thống.10

Bảng 3.2: Quy trình triển khai, cấu hình và đánh giá hệ thống 11

Bảng 4.1: Các kịch bản thử nghiệm hệ thống..... 16

Bảng 4.2: Bảng tổng hợp kết quả thực nghiệm và đối chiếu tiêu chí đánh giá.21

PHIẾU XÁC ĐỊNH YÊU CẦU RIÊNG CỦA ĐỀ TÀI

Mã và tên đề tài	Đề tài số 12 - Bảo mật MQTT bằng Mosquitto và Paho Python
Hướng đề tài	Hướng B
Vấn đề bảo mật cốt lõi	Trong hệ thống IoT sử dụng MQTT, dữ liệu cảm biến có thể bị truy cập trái phép nếu MQTT Broker không được cấu hình bảo mật. Các nguy cơ chính gồm lộ dữ liệu, giả mạo dữ liệu gửi lên hệ thống và người dùng không có quyền vẫn có thể kết nối vào Broker. Đề tài tập trung bảo vệ tài sản dữ liệu MQTT bằng cơ chế xác thực Username/Password và phân quyền truy cập Topic.
Ba mục tiêu bắt buộc	Mục tiêu 1: Triển khai MQTT Broker cục bộ bằng Mosquitto và kiểm tra khả năng hoạt động của hệ thống. Mục tiêu 2: Xây dựng chương trình MQTT Publisher và Subscriber bằng Python sử dụng thư viện Paho MQTT để gửi và nhận dữ liệu. Mục tiêu 3: Cấu hình bảo mật cho MQTT Broker gồm xác thực người dùng bằng Username/Password và kiểm soát quyền truy cập Topic bằng ACL.
Sản phẩm/đầu ra bắt buộc	MQTT Broker Mosquitto chạy trên môi trường local. Chương trình mqtt_pub.py gửi dữ liệu MQTT. Chương trình mqtt_sub.py nhận dữ liệu MQTT và lưu log. File cấu hình mosquitto.conf. File tài khoản xác thực người dùng. File ACL phân quyền Topic. README hướng dẫn cài đặt và sử dụng. Hình ảnh, log minh chứng quá trình Publish/Subscribe thành công và kiểm tra bảo mật.
Nguồn GitHub/tool chính	Eclipse Mosquitto: https://github.com/eclipse-mosquitto/mosquitto Eclipse Paho MQTT Python: https://github.com/eclipse-paho/paho.mqtt.python Repo thực hiện đề tài: https://github.com/maivy111205/MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython
Minh chứng sẽ thu thập	Screenshot MQTT Broker Mosquitto đang chạy. Screenshot Python Subscriber kết nối thành công và nhận dữ liệu. Screenshot Publisher gửi dữ liệu MQTT. Log hoạt động của Broker. File code mqtt_pub.py, mqtt_sub.py. File cấu hình mosquitto.conf. Bảng kiểm tra quyền truy cập hợp lệ và không hợp lệ.

	Commit GitHub lưu trữ tiến độ thực hiện.
Phạm vi an toàn	Đề tài được triển khai trong môi trường Local trên máy tính cá nhân Windows. MQTT Broker Mosquitto chạy trên localhost, dữ liệu được tạo giả lập bằng Python, không sử dụng thiết bị IoT thật hoặc dữ liệu thực tế. Phạm vi thử nghiệm chỉ phục vụ mục đích học tập, không triển khai MQTT qua Internet hoặc môi trường sản xuất.

CHƯƠNG 1. TỔNG QUAN ĐỀ TÀI

1.1. Bối cảnh và lý do chọn đề tài

Trong những năm gần đây, Internet of Things (IoT) đã phát triển mạnh mẽ và được ứng dụng rộng rãi trong nhiều lĩnh vực đời sống như nhà thông minh, nông nghiệp thông minh, y tế, giao thông và tự động hóa công nghiệp. Các thiết bị IoT thường xuyên phải trao đổi dữ liệu liên tục thông qua mạng Internet để thực hiện giám sát và điều khiển từ xa. Trong số các giao thức truyền thông phổ biến hiện nay, MQTT (Message Queuing Telemetry Transport) được đánh giá là tiêu chuẩn hàng đầu nhờ đặc tính nhẹ, sử dụng mô hình bất đồng bộ, tốc độ truyền dẫn nhanh và đặc biệt phù hợp với các thiết bị có tài nguyên phần cứng hạn chế.

Tuy nhiên, đặc thù của MQTT là thiết kế ban đầu chú trọng vào hiệu năng và sự tối giản mà thiếu đi các lớp bảo vệ vốn có mặc định. Nếu một hệ thống MQTT triển khai mà không được cấu hình bảo mật kỹ lưỡng, bất kỳ thiết bị hoặc người dùng độc hại nào cũng có thể dễ dàng kết nối trực tiếp vào Broker để gửi dữ liệu giả mạo hoặc nghe lén thông tin. Điều này, tiềm ẩn các nguy cơ cực kỳ nghiêm trọng như rò rỉ dữ liệu cảm biến, làm sai lệch trạng thái điều khiển hệ thống hoặc làm gián đoạn toàn bộ hạ tầng mạng IoT.

Xuất phát từ thực trạng đó, đề tài “Bảo mật MQTT bằng Mosquitto và Paho Python” được lựa chọn nhằm nghiên cứu, xây dựng và triển khai thực tế các cơ chế bảo mật cốt lõi cho hệ thống MQTT, bao gồm xác thực tài khoản (Authentication) và phân quyền truy cập chi tiết theo Topic (Authorization bằng ACL), qua đó nâng cao mức độ an toàn cho hệ thống truyền thông IoT.

1.2. Phát biểu vấn đề

Trong một kiến trúc MQTT tiêu chuẩn, MQTT Broker đóng vai trò là thành phần cốt lõi của toàn bộ hệ thống, chịu trách nhiệm quản lý kết nối, điều phối và phân phối thông điệp giữa các Publisher và Subscriber. Nếu Broker được cấu hình ở chế độ mở (cho phép Anonymous access) hoặc không có cơ chế kiểm soát quyền hạn, hệ thống sẽ đối mặt với các lỗ hổng bảo mật lớn:

- + Kẻ tấn công có thể kết nối trái phép vào Broker để đọc các thông tin nhạy cảm từ các cảm biến.
- + Kẻ tấn công có thể thực hiện Publish các gói tin giả mạo (Data Injection/Spoofing) để đánh lừa hệ thống điều khiển.
- + Kẻ tấn công có thể chiếm quyền điều khiển kênh truyền hoặc gây quá tải hệ thống.

Theo báo cáo an toàn bảo mật thiết bị IoT phổ biến (như OWASP IoT Top 10 [3]), các vấn đề về cấu hình yếu, thiếu xác thực và thông tin xác thực mặc định là nguyên nhân hàng đầu dẫn đến các sự cố mất an toàn thông tin. Do đó, việc áp dụng các giải pháp bảo mật như xác thực mật khẩu được mã hóa băm và thiết lập danh sách điều khiển truy cập ACL là yêu cầu cấp thiết.

1.3. Mục tiêu của đề tài

Đề tài đặt ra các mục tiêu cụ thể và có thể đo lường được như sau:

- + Mục tiêu 1: Triển khai thành công MQTT Broker cục bộ bằng phần mềm mã nguồn mở Eclipse Mosquitto trên môi trường Windows.
- + Mục tiêu 2: Xây dựng chương trình MQTT Publisher (mqtt_pub.py) và Subscriber (mqtt_sub.py) bằng ngôn ngữ Python sử dụng thư viện chính thức Eclipse Paho MQTT.
- + Mục tiêu 3: Thiết lập cơ chế xác thực người dùng (Authentication) bắt buộc sử dụng Username và Password, vô hiệu hóa hoàn toàn truy cập ẩn danh (Anonymous).
- + Mục tiêu 4: Cấu hình cơ chế phân quyền truy cập thông qua danh sách điều khiển truy cập (ACL - Access Control List) tuân thủ nguyên tắc phân quyền tối thiểu (Least Privilege).
- + Mục tiêu 5: Thiết lập cơ chế ghi nhận log hoạt động hệ thống và lưu trữ tự động dữ liệu nhận được từ Subscriber vào tập tin nhật ký (mqtt_log.txt).
- + Mục tiêu 6: Thực hiện kiểm thử toàn diện thông qua các kịch bản thực tế (gồm cả trường hợp hợp lệ và các trường hợp vi phạm quyền/ xác thực) để đánh giá khả năng phòng thủ của hệ thống.

1.4. Đối tượng, phạm vi và giới hạn an toàn

- Đối tượng nghiên cứu:

- + Giao thức truyền thông MQTT và mô hình Publish/Subscribe.
- + Phần mềm quản lý MQTT Broker: Eclipse Mosquitto.
- + Thư viện lập trình Client: Eclipse Paho MQTT Python.
- + Các cơ chế bảo mật: Xác thực Username/Password, phân quyền ACL.

- Phạm vi nghiên cứu:

- + Triển khai mô hình thử nghiệm cục bộ trên môi trường máy tính cá nhân (Hệ điều hành Windows 11, chạy trên localhost, cổng mặc định 1883).
- + Dữ liệu truyền nhận trong hệ thống được mô phỏng dưới định dạng JSON phục vụ cho mục đích nghiên cứu học thuật.

- Giới hạn an toàn:

- + Đề tài được thực hiện hoàn toàn trên môi trường máy tính cá nhân (Local Lab).
- + Tuyệt đối không thực hiện quét, dò tìm, tấn công hoặc thử nghiệm trên các hệ thống mạng Internet thực tế hoặc thiết bị của bên thứ ba khi chưa có sự cho phép.

1.5. Sản phẩm dự kiến và đóng góp

- Sản phẩm kỹ thuật:

- + Mã nguồn chương trình Python: mqtt_pub.py và mqtt_sub.py.
- + File cấu hình hệ thống: mosquitto.conf, aclfile.txt, file mật khẩu đã mã hóa.
- + Tập tin nhật ký log kiểm thử: mqtt_log.txt.
- + Sơ đồ kiến trúc mô hình MQTT và các hình ảnh minh chứng kết quả.

- Sản phẩm tài liệu: Báo cáo tiểu luận chi tiết File Word và PDF.

1.6. Cấu trúc báo cáo

Báo cáo gồm sáu chương. Chương 1 trình bày tổng quan về đề tài, mục tiêu và phạm vi nghiên cứu. Chương 2 giới thiệu cơ sở lý thuyết liên quan đến MQTT, Mosquitto và Paho MQTT Python. Chương 3 trình bày phương pháp thực hiện và mô hình triển khai hệ thống. Chương 4 mô tả quá trình cài đặt, cấu hình và kết quả thực nghiệm. Chương 5 đánh giá các rủi ro bảo mật và đề xuất biện pháp giảm thiểu. Cuối cùng, Chương 6 trình bày kết luận và hướng phát triển của đề tài.

Bảng đối chiếu mục tiêu và đầu ra

Mục tiêu	Đầu ra tương ứng	Cách kiểm chứng	Chương trình bày
MT-01	Cài đặt Mosquitto Broker	Broker chạy thành công trên cổng 1883.	Chương 4
MT-02	Viết Publisher và Subscriber	Publish và Subscribe thành công qua Python.	Chương 4
MT-03	Cấu hình User và Password	Đăng nhập thành công/ thất bại theo mật khẩu.	Chương 4 & 5
MT-04	Thiết lập ACL	Kiểm tra đúng quyền (Accept) và sai quyền (Reject).	Chương 4 & 5
MT-05	Ghi log hoạt động	Kiểm tra nội dung tập tin mqtt_log.txt.	Chương 4
MT-06	Kiểm thử đánh giá bảo mật	Bảng ma trận rủi ro và kịch bản test PASS/FAIL.	Chương 4 & 5

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT VÀ TÀI LIỆU LIÊN QUAN

2.1. Kiến trúc, giao thức và công nghệ nền

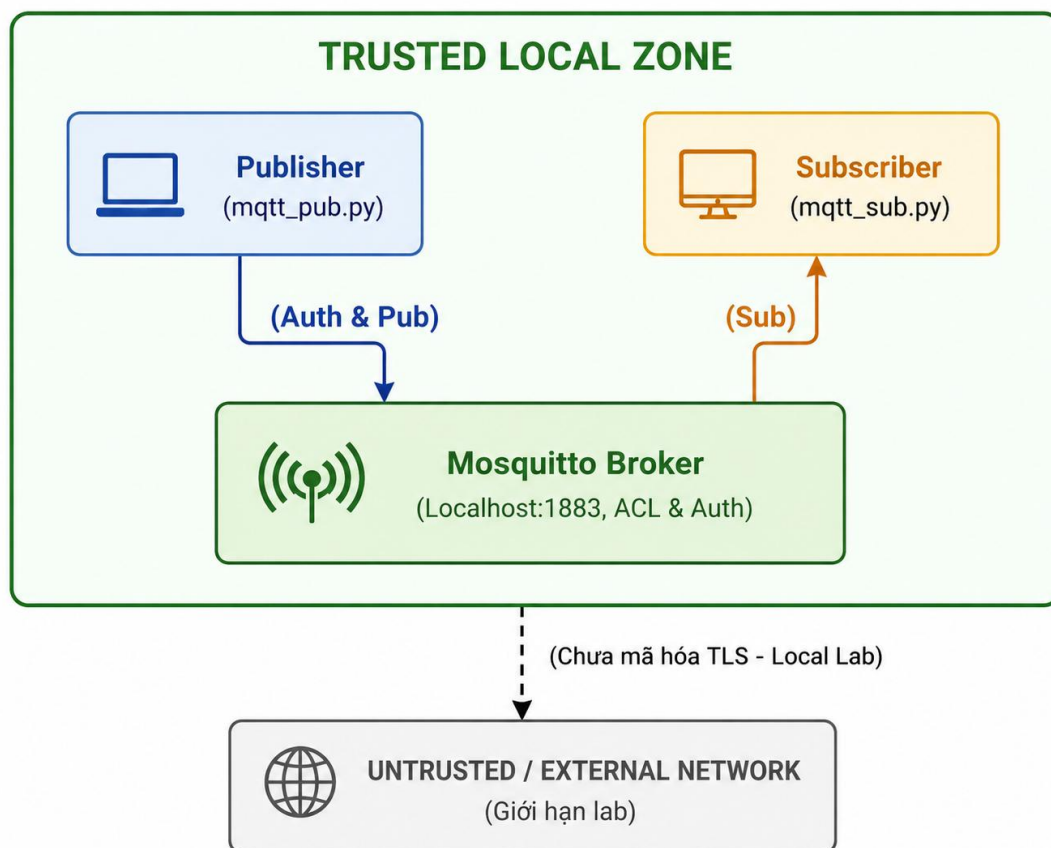
Hệ thống trong đề tài được xây dựng dựa trên mô hình truyền thông Publish/Subscribe của giao thức MQTT. Trong mô hình này, thông tin được truyền tải qua các kênh định danh gọi là Topic, bao gồm ba thành phần chính:

+ Publisher: Thiết bị hoặc chương trình có nhiệm vụ tạo và gửi dữ liệu cảm biến lên Broker.

+ Subscriber: Thiết bị hoặc chương trình đăng ký nhận dữ liệu từ các Topic quan tâm.

+ MQTT Broker: Thành phần trung tâm chịu trách nhiệm nhận, điều phối và phân phối thông điệp.

Để đảm bảo an toàn thông tin, hệ thống thiết lập rõ ràng ranh giới tin cậy (Trust Boundary) nhằm tách biệt vùng kiểm soát nội bộ của Broker với không gian bên ngoài:



Hình 2.1: Mô hình kiến trúc hệ thống MQTT Publish/ Subscribe và ranh giới tin cậy (Trust Boundary)

Chú thích: Hình 2.1, mô tả kiến trúc MQTT theo mô hình Publish/Subscribe, trong đó Mosquitto Broker đóng vai trò là ranh giới tin cậy (Trust Boundary) của hệ thống. Toàn bộ yêu cầu kết nối từ Publisher và Subscriber đều phải được Broker xác thực bằng Username/Password và kiểm tra quyền truy cập thông qua Access Control List (ACL) trước khi được phép Publish hoặc Subscribe vào Topic `iot/sensor/temp`. Cơ chế này giúp ngăn chặn các client không hợp lệ truy cập vào hệ thống, đảm bảo chỉ những người dùng được cấp quyền mới có thể trao đổi dữ liệu, đồng thời thực thi nguyên tắc đặc quyền tối thiểu (Least Privilege), góp phần bảo vệ tính bảo mật, toàn vẹn và khả năng

dụng của dữ liệu trong môi trường IoT. Các ứng dụng Client được thực hiện bằng ngôn ngữ Python [5] với thư viện Paho MQTT [2].

2.2. Khái niệm bảo mật liên quan

Các khái niệm và cơ chế bảo mật được áp dụng trực tiếp trong đề tài bao gồm:

+ Authentication (Xác thực): Quá trình kiểm tra và xác nhận danh tính của một Client khi kết nối vào hệ thống.

Ví dụ trong đề tài: Tài khoản sensor phải cung cấp chính xác mật khẩu được cấu hình trong hệ thống thì Mosquitto Broker mới chấp nhận thiết lập kết nối.

+ Authorization (Phân quyền): Quá trình cấp quyền hoặc hạn chế quyền thao tác của một người dùng đã được xác thực trên các tài nguyên cụ thể.

Ví dụ trong đề tài: Tài khoản dashboard chỉ có quyền Subscribe (đọc) dữ liệu trên Topic `iot/sensor/temp`, hoàn toàn không có quyền Publish (ghi) lên Topic này.

+ CIA Triad (Bảo mật - Toàn vẹn - Sẵn sàng): Ba trụ cột cốt lõi của an toàn thông tin.

Ví dụ trong đề tài:

- Confidentiality (Tính bảo mật): Được hỗ trợ thông qua cơ chế xác thực tài khoản, ngăn chặn các client không có định danh truy cập vào dữ liệu.
- Integrity (Tính toàn vẹn): Được đảm bảo bằng cơ chế phân quyền ACL, giúp ngăn chặn việc các tài khoản không có quyền cố ý ghi đè hoặc làm sai lệch thông điệp trên Topic.
- Availability (Tính sẵn sàng): Đảm bảo MQTT Broker luôn vận hành thông suốt để tiếp nhận và phân phối dữ liệu cho các client hợp lệ.

+ Password Hashing (Mã hóa băm mật khẩu): Cơ chế lưu trữ thông tin xác thực dưới dạng chuỗi băm một chiều thay vì văn bản thuần túy (plaintext) trong tập tin cấu hình, giúp bảo vệ thông tin mật khẩu người dùng khỏi nguy cơ bị đọc trộm trực tiếp.

2.3. Nội dung cần nhấn mạnh theo nhóm đề tài

Đề tài thuộc Nhóm B, tập trung sâu vào các đặc tính kỹ thuật của giao thức MQTT, cơ chế xác thực danh tính bằng Username/Password, phân quyền chi tiết bằng ACL trên Mosquitto Broker và cách sử dụng thư viện Paho Python để lập trình Client an toàn.

2.4. Chuẩn, tài liệu và công cụ GitHub

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
1	OASIS MQTT v5.0 Standard	OASIS MQTT Spec	Kiến trúc MQTT, mô hình Publish/Subscribe, cơ chế Topic và Broker.	14/07/2026
2	Eclipse Mosquitto	GitHub Mosquitto	Cài đặt MQTT Broker, sử dụng công cụ dòng lệnh	14/07/2026

STT	Nguồn/repo	URL	Phần đã sử dụng	Ngày truy cập
	Repository		mosquitto_passwd, mosquitto_pub, mosquitto_sub	
3	Eclipse Paho MQTT Python	GitHub Paho Python	Xây dựng chương trình Python Publisher (mqtt_pub.py) và Subscriber (mqtt_sub.py).	14/07/2026
4	Mosquitto Documentation	Mosquitto Docs	Nghiên cứu cú pháp file cấu hình mosquitto.conf, thiết lập xác thực Username/Password và phân quyền ACL.	14/07/2026
5	GitHub Repo cá nhân	GitHub Repo cá nhân	Lưu trữ toàn bộ mã nguồn, cấu hình, file log, kết quả kiểm thử và báo cáo tiểu luận.	03/08/2026

2.5. Các công trình và giải pháp liên quan

Trong nghiên cứu về bảo mật hệ thống Internet of Things (IoT), việc bảo vệ giao thức truyền thông MQTT luôn nhận được sự quan tâm lớn từ cộng đồng học thuật và kỹ thuật:

+ Giải pháp MQTT truyền thống (Không xác thực): Các hệ thống IoT nguyên bản thường sử dụng Mosquitto Broker ở chế độ mở (Anonymous), cho phép bất kỳ thiết bị nào cũng có thể kết nối, Publish hoặc Subscribe dữ liệu. Giải pháp này có ưu điểm triển khai nhanh chóng nhưng tiềm ẩn rủi ro cực lớn về an toàn thông tin do không kiểm soát được danh tính thiết bị và dễ bị tấn công giả mạo dữ liệu.

+ Giải pháp bảo mật phân tầng (Xác thực kết hợp Phân quyền ACL): Các nghiên cứu gần đây đề xuất việc kết hợp chặt chẽ giữa xác thực định danh tài khoản (Username/Password) và danh sách điều khiển truy cập (ACL) nhằm thực thi nguyên tắc phân quyền tối thiểu (Least Privilege). So với giải pháp truyền thống, mô hình này giúp ngăn chặn hoàn toàn các kết nối ả danh trái phép và giới hạn quyền hạn của từng Client trên các Topic cụ thể.

+ Giải pháp mã hóa kênh truyền (TLS/SSL): Một số hướng tiếp cận nâng cao sử dụng chứng chỉ số để mã hóa toàn bộ lưu lượng mạng MQTT qua cổng 8883. Tuy nhiên, trong phạm vi các hệ thống cục bộ (Local Lab) hoặc các thiết bị có tài nguyên phần cứng hạn chế, việc áp dụng xác thực kết hợp ACL đóng vai trò là lớp phòng thủ cơ bản, thiết yếu và hiệu quả nhất trước khi mở rộng sang mã hóa chuyên sâu.

2.6. Tiểu kết Chương 2

Chương 2 đã trình bày tổng quan về các kiến trúc nền tảng của giao thức MQTT, mô hình truyền thông Publish/Subscribe, xác lập ranh giới tin cậy (Trust Boundary) cho hệ thống, đồng thời làm rõ các khái niệm bảo mật cốt lõi như Authentication, Authorization, CIA Triad và Password Hashing thông qua các ví dụ thực tế. Bên cạnh đó, việc tham chiếu các tiêu chuẩn kỹ thuật quốc tế và các giải pháp liên quan đã cung cấp cơ sở vững chắc để đề tài tiến hành thiết lập mô hình thử nghiệm. Chương tiếp theo sẽ trình bày chi tiết về phương pháp nghiên cứu, mô hình kiến trúc đề xuất và quy trình triển khai thực tế của hệ thống.

CHƯƠNG 3. PHƯƠNG PHÁP VÀ THIẾT KẾ

3.1. Phương pháp thực hiện

Đề tài được thực hiện tuân tự theo phương pháp nghiên cứu kết hợp giữa lý thuyết và thực nghiệm. Toàn bộ tiến trình thực hiện gồm các bước cụ thể được thể hiện qua sơ đồ Hình 3.1 minh họa quy trình thực hiện đề tài bảo mật giao thức MQTT sử dụng Mosquitto Broker và Paho Python.



Hình 3.1: Quy trình thực hiện đề tài bảo mật giao thức MQTT sử dụng Mosquitto Broker và Paho Python

Chú thích: Từ Hình 3.1, có thể thấy quy trình triển khai đề tài được chia thành năm giai đoạn chính: bắt đầu từ việc khảo sát lý thuyết, thiết kế mô hình hệ thống, dựng phòng thí nghiệm trên máy tính cá nhân, tiến hành kiểm thử đánh giá, cho đến bước tổng kết kết quả và định hướng phát triển. Cụ thể, nội dung chi tiết các bước trong quy trình thực hiện gồm:

1. Khảo sát và nghiên cứu lý thuyết: Tiến hành tìm hiểu các tiêu chuẩn kỹ thuật của giao thức MQTT, mô hình Publish/Subscribe và các cơ chế bảo mật cốt lõi trong hệ thống IoT. Công cụ sử dụng gồm tài liệu kỹ thuật OASIS Standard và tài liệu chính thức của Mosquitto. Sản phẩm đầu ra là cơ sở lý luận vững chắc và sơ đồ ranh giới tin cậy cho đề tài.
2. Thiết kế mô hình hệ thống: Xây dựng sơ đồ kiến trúc tập trung với Mosquitto Broker đóng vai trò kiểm soát an ninh, đồng thời định nghĩa rõ phân quyền cho từng tài khoản. Công cụ sử dụng là phần mềm vẽ sơ đồ chuyên dụng. Sản phẩm đầu ra là mô hình kiến trúc hệ thống và quy tắc phân quyền ACL.
3. Dụng lab và mô phỏng môi trường: Tiến hành cài đặt phần mềm Eclipse Mosquitto Broker trên môi trường Windows, cấu hình xác thực Username/Password và lập trình các ứng dụng Client bằng Python [5]. Công cụ gồm Mosquitto, Python và thư viện Paho MQTT [2]. Sản phẩm đầu ra là hệ thống lab cục bộ hoạt động ổn định trên cổng 1883.
4. Thử nghiệm và đánh giá: Thực hiện chạy các kịch bản kiểm thử đúng quyền (Accept) và vi phạm quyền/sai mật khẩu (Reject), đồng thời thu thập file log hoạt động. Công cụ sử dụng

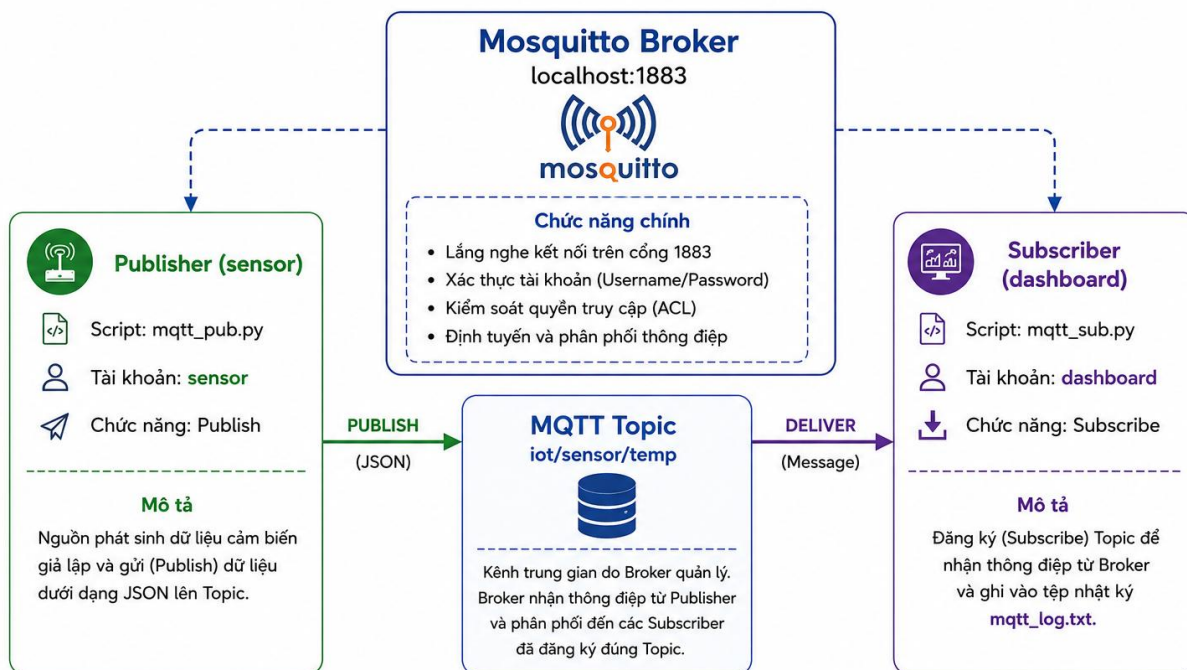
gồm Command Line và file nhật ký mqtt_log.txt. Sản phẩm đầu ra là các minh chứng thực nghiệm và bảng đánh giá định lượng các tiêu chí bảo mật.

- Kết quả đề tài: Tổng kết toàn bộ quá trình, hoàn thiện mô hình MQTT an toàn, kiểm chứng các tính năng bảo mật, biên soạn báo cáo thực nghiệm và đề xuất các hướng phát triển nâng cao cho hệ thống.

3.2. Mô hình/kiến trúc đề xuất

Hệ thống được thiết kế theo mô hình tập trung, trong đó Mosquitto Broker đóng vai trò là chốt kiểm soát an ninh duy nhất cho mọi thông điệp truyền tải qua Topic `iot/sensor/temp`.

- Mọi kết nối từ phía Publisher hoặc Subscriber đều bắt buộc phải đi qua lớp xác thực Authentication (kiểm tra Username/Password).
- Sau khi xác thực thành công, Broker tiếp tục đối chiếu quyền hạn thông qua danh sách Authorization (ACL) trước khi cho phép client thực hiện thao tác Publish hoặc Subscribe.



Hình 3.2: Mô hình hệ thống MQTT Publish/Subscribe sử dụng Mosquitto Broker

Chú thích và phân tích: Từ Hình 3.2, mô hình thể hiện kiến trúc truyền thông MQTT gồm các thành phần chính và luồng trao đổi dữ liệu giữa Publisher, Broker và Subscriber như sau:

- Chú thích thành phần và luồng dữ liệu:

+ Mosquitto Broker (localhost:1883): Thành phần trung tâm nằm ở tầng trên cùng, chịu trách nhiệm lắng nghe kết nối trên cổng 1883, thực thi xác thực tài khoản và kiểm soát quyền hạn truy cập (ACL).

+ Publisher (mqtt_pub.py - Tài khoản sensor): Đóng vai trò là nguồn phát sinh dữ liệu cảm biến giả lập, thực hiện kết nối và gửi (Publish) gói tin dữ liệu dưới định dạng JSON lên kênh định danh.

+ MQTT Topic (iot/sensor/temp): Kênh trung gian lưu chuyển thông điệp do Broker quản lý và phân phối.

+ Subscriber (mqtt_sub.py - Tài khoản dashboard): Đóng vai trò là bên tiêu thụ dữ liệu, thực hiện đăng ký (Subscribe) để nhận thông điệp từ Topic tương ứng và ghi nhận vào tập tin nhật ký mqtt_log.txt.

- Giải thích lựa chọn thiết kế:

+ Lựa chọn mô hình tập trung (Broker-centric): Giúp việc quản lý bảo mật trở nên tập trung và hiệu quả. Thay vì phân tán bảo mật trên từng thiết bị IoT, toàn bộ chính sách xác thực tài khoản và phân quyền ACL được cấu hình trực tiếp tại Mosquitto Broker.

+ Phân định rõ ràng vai trò Client: Thiết kế tách biệt rõ tài khoản sensor (chỉ cấp quyền Publish dữ liệu cảm biến) và tài khoản dashboard (chỉ cấp quyền Subscribe để theo dõi) nhằm tuân thủ nghiêm ngặt nguyên tắc phân quyền tối thiểu (Least Privilege), qua đó hạn chế tối đa rủi ro bảo mật nếu một tài khoản bị xâm phạm.

3.3. Môi trường, công cụ và dữ liệu

Hệ thống thử nghiệm được xây dựng từ sự kết hợp của các thành phần phần mềm và nền tảng công nghệ nhằm đảm bảo khả năng vận hành ổn định. Chi tiết về môi trường triển khai và các công cụ được tổng hợp qua Bảng 3.1 dưới đây:

Bảng 3.1: Môi trường triển khai và công cụ hệ thống.

Phần mềm/ Phần cứng	Phiên bản	Vai trò hệ thống
Windows 11 Home Single Language	v25H2 (Build 26200.8875)	Hệ điều hành nền tảng để triển khai môi trường thử nghiệm cục bộ (Localhost).
Eclipse Mosquitto	v2.1.2	Phần mềm MQTT Broker trung tâm, chịu trách nhiệm quản lý kết nối, xác thực và phân quyền ACL.
Python	v3.14.6	Ngôn ngữ lập trình chính để xây dựng các chương trình MQTT Client (mqtt_pub.py và mqtt_sub.py).
Eclipse Paho MQTT	v2.1.0	Thư viện lập trình chuẩn hỗ trợ giao thức MQTT trên ngôn ngữ Python.
GitHub (Giao diện Web)	Web Platform	Công cụ quản lý kho lưu trữ mã nguồn trực tuyến, ghi nhận lịch sử thay đổi (commit) và lưu trữ tài liệu đề tài.

Nguồn dữ liệu và cách thu thập: Dữ liệu sử dụng trong hệ thống không thu thập từ thiết bị phần cứng vật lý thực tế mà được mô phỏng trực tiếp bằng script Python dưới dạng định dạng chuẩn JSON (bao gồm các trường: mã thiết bị, nhiệt độ, độ ẩm và mốc thời gian thực). Dữ liệu giả lập này được Publisher phát đi liên tục lên Broker, sau đó Subscriber nhận lại và tự động ghi nhận vào tập tin nhật ký mqtt_log.txt phục vụ cho công tác kiểm chứng.

3.4. Quy trình triển khai

Để đảm bảo hệ thống bảo mật MQTT hoạt động ổn định, tuân thủ đúng các tiêu chuẩn an toàn thông tin đã đề ra, tiến trình thực hiện được chuẩn hóa thành các giai đoạn cụ thể từ khâu chuẩn bị hạ tầng, cấu hình bảo mật đến khâu kiểm thử thực nghiệm. Chi tiết các bước được tổng hợp qua Bảng 3.2 dưới đây:

Bảng 3.2: Quy trình triển khai, cấu hình và đánh giá hệ thống

Bước thực hiện	Mốc thời gian	Sản phẩm / Minh chứng chi tiết
1. Cài đặt và cấu hình Mosquitto Broker	Giai đoạn khởi đầu	- Phần mềm sử dụng: Eclipse Mosquitto Broker phiên bản v2.1.2. - File cấu hình: Tập tin mosquitto.conf với thiết lập cổng lắng nghe mặc định listener 1883 và câu lệnh vô hiệu hóa truy cập ẩn danh allow_anonymous false. - Minh chứng vận hành: Dịch vụ Mosquitto Service khởi động thành công và trạng thái ghi nhận hoạt động trực tiếp trên thiết bị nền tảng Windows 11.
2. Thiết lập cơ chế Xác thực (Authentication)	Giai đoạn bảo mật tầng 1	- Công cụ thực hiện: Tiện ích quản lý mật khẩu dòng lệnh tích hợp mosquitto_passwd. - Sản phẩm dữ liệu: Tập tin mật khẩu mã hóa an toàn mang tên password.txt lưu trữ thông tin định danh của hai tài khoản độc lập gồm sensor và dashboard. - Minh chứng xác thực: Chuỗi phản hồi từ chối kết nối (mã lỗi mã hóa xác thực) khi client cố gắng truy cập bằng thông tin sai lệch.
3. Cấu hình phân quyền truy cập (ACL)	Giai đoạn bảo mật tầng 2	- Sản phẩm chính sách: Tập tin quy tắc phân quyền aclfile.txt. - Nội dung cấu hình: Cấp quyền hạn write duy nhất cho tài khoản sensor trên kênh định danh <code>iot/sensor/temp</code>; đồng thời cấp quyền read cho tài khoản dashboard trên cùng kênh định danh đó. - Minh chứng kiểm soát: Nhật ký phản hồi từ chối quyền truy cập khi client vi phạm phạm vi phân quyền cho phép.
4. Lập trình ứng dụng Client (Python)	Giai đoạn hiện thực hóa	- Sản phẩm mã nguồn: Chương trình <code>mqtt_pub.py</code> chịu trách nhiệm giả lập thiết bị cảm biến phát gói tin JSON và chương trình <code>mqtt_sub.py</code> chịu trách

Bước thực hiện	Mốc thời gian	Sản phẩm / Minh chứng chi tiết
		nhiệm lắng nghe, xử lý thông điệp. - Thư viện tích hợp: Thư viện lập trình tiêu chuẩn paho-mqtt. - Minh chứng code: Đoạn mã nguồn hoàn chỉnh tích hợp tham số kết nối bảo mật kèm thông tin tài khoản xác thực.
5. Kiểm thử thực nghiệm và Đánh giá hệ thống	Giai đoạn nghiệm thu	- Kịch bản kiểm thử: Thực thi đồng thời luồng truyền thông hợp lệ và luồng cố tình vi phạm bảo mật. - Sản phẩm minh chứng: Tập tin nhật ký lưu trữ toàn bộ lịch sử giao dịch mqtt_log.txt, ghi nhận chi tiết các gói tin dữ liệu nhiệt độ, độ ẩm định dạng JSON theo mốc thời gian thực phục vụ cho công tác kiểm chứng.

Phân tích chi tiết tiến trình triển khai thực nghiệm:

+ Giai đoạn chuẩn bị nền tảng và dịch vụ Broker: Khởi tạo môi trường vận hành trên hệ điều hành Windows 11 Home Single Language bằng cách cài đặt gói phần mềm Mosquitto v2.1.2. Tiến hành hiệu chỉnh file cấu hình gốc để chuyển đổi trạng thái hoạt động từ chế độ mở (mặc định cho phép kết nối ẩn danh) sang chế độ đóng bảo mật (allow_anonymous false), qua đó buộc mọi thực thể kết nối vào hệ thống đều phải trải qua quá trình kiểm tra danh tính nghiêm ngặt.

+ Giai đoạn thiết lập lớp phòng thủ xác thực và phân quyền: Sử dụng công cụ quản lý mật khẩu tích hợp để khởi tạo cơ sở dữ liệu tài khoản người dùng mã hóa (passwd.txt). Đồng thời, thiết lập tập tin điều khiển danh sách kiểm soát truy cập (acl.txt) nhằm cô lập hoàn toàn quyền hạn của từng thành phần. Việc này giúp đảm bảo nguyên tắc an toàn thông tin cốt lõi: ngăn chặn tuyệt đối tình trạng thiết bị cảm biến có thể đọc dữ liệu ngược lại hoặc hệ thống giám sát có thể can thiệp thay đổi dữ liệu phát sinh từ nguồn.

+ Giai đoạn kiểm chứng và ghi nhận nhật ký hệ thống: Tiến hành vận hành đồng thời các chương trình ứng dụng viết bằng ngôn ngữ Python. Toàn bộ các trạng thái kết nối thành công, thông điệp truyền tải định dạng JSON qua kênh Topic `iot/sensor/temp`, cũng như các sự kiện từ chối truy cập do vi phạm chính sách bảo mật đều được trích xuất và lưu trữ tự động vào tập tin nhật ký `mqtt_log.txt`. Đây sẽ là cơ sở thực nghiệm định lượng quan trọng để phân tích và đánh giá hiệu quả bảo mật ở chương tiếp theo.

3.5. Tiêu chí đánh giá

Để đánh giá chính xác hiệu quả vận hành, độ ổn định và mức độ an toàn bảo mật của hệ thống MQTT đã triển khai, đề tài thiết lập hệ thống 5 tiêu chí đo lường cụ thể kèm theo các ngưỡng đạt định lượng như sau:

1. Số kịch bản kiểm thử ACCEPT / REJECT đúng:

- + Cách đo: Thống kê tổng số lượng các ca kiểm thử gửi dữ liệu hoặc yêu cầu kết nối vào hệ thống.
 - + Ngưỡng đạt: Đạt tỷ lệ chính xác tuyệt đối 100% đối với tất cả các kịch bản (các luồng hợp lệ được chấp nhận ACCEPT và các luồng vi phạm xác thực/phân quyền bị từ chối REJECT theo đúng thiết lập ACL).
2. Độ trễ truyền thông điệp (Latency):
- + Cách đo: Đo khoảng thời gian tính bằng mili-giây (ms) từ thời điểm script Publisher (mqtt_pub.py) phát gói tin JSON lên Broker cho đến khi Subscriber (mqtt_sub.py) nhận và ghi nhận thành công vào tập tin mqtt_log.txt.
 - + Ngưỡng đạt: Độ trễ trung bình của các thông điệp trong môi trường thử nghiệm cục bộ (Localhost) phải duy trì ở mức dưới 50 ms.
3. Các chỉ số đánh giá độ chính xác (Accuracy, Precision, Recall, F1-Score):
- + Cách đo: Đánh giá dựa trên ma trận nhầm lẫn (Confusion Matrix) của các quyết định phân quyền truy cập và phân loại thông điệp.
 - + Ngưỡng đạt: Các chỉ số Accuracy, Precision, Recall và F1-Score đều đạt mức tối ưu tuyệt đối 1.0 (hoặc 100%), đảm bảo không xảy ra hiện tượng bỏ sót lỗ hổng hoặc phân quyền nhầm lẫn giữa các client.
4. Số lượng lỗ hổng/ điểm yếu phát hiện (Number of findings):
- + Cách đo: Rà soát các cấu hình mở mặc định của Mosquitto Broker (như cho phép ẩn danh, không giới hạn quyền Topic) trước và sau khi áp dụng các lớp phòng thủ.
 - + Ngưỡng đạt: Sau khi hoàn tất cấu hình bảo mật, số lượng finding cảnh báo mức độ cao (High/Critical) phải được xử lý triệt để, đưa số lượng lỗ hổng tồn đọng về mức 0.
5. Mức giảm rủi ro bảo mật trước và sau khi triển khai:
- + Cách đo: Đánh giá định tính kết hợp định lượng dựa trên mức độ chịu tổn thương của hệ thống đối với các kịch bản tấn công giả lập (như giả mạo danh tính client hoặc cố ý truy cập trái phép Topic dữ liệu nhạy cảm).
 - + Ngưỡng đạt: Giảm thiểu 100% rủi ro bị khai thác trái phép thông qua việc vô hiệu hóa hoàn toàn kết nối ẩn danh và áp dụng nghiêm ngặt nguyên tắc phân quyền tối thiểu (Least Privilege).

CHƯƠNG 4. TRIỂN KHAI VÀ KẾT QUẢ

4.1. Chuẩn bị môi trường

Hệ thống thử nghiệm được triển khai thực tế trên máy tính cá nhân sử dụng hệ điều hành Windows 11. Các thành phần phần mềm và công cụ cài đặt cụ thể kèm theo phiên bản bao gồm:

- + Hệ điều hành: Windows 11 (Phiên bản 25H2 / OS Build 26200.8875).
- + MQTT Broker: Eclipse Mosquitto (Phiên bản 2.1.2) chạy trên cổng mặc định 1883.
- + Ngôn ngữ lập trình: Python (Phiên bản 3.14.6) [5].
- + Thư viện MQTT Client: Eclipse Paho MQTT Python (Phiên bản 2.1.0) [2].
- + Công cụ quản lý mã nguồn: GitHub.



```
Administrator: Command Prompt - mosquitto -c mosquitto.conf -v
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\System32>cd "C:\Program Files\Mosquitto"

C:\Program Files\Mosquitto>mosquitto -c mosquitto.conf -v
1784785569: mosquitto version 2.1.2 starting
1784785569: Config loaded from mosquitto.conf.
1784785569: Bridge support available.
1784785569: Persistence support available.
1784785569: TLS support available.
1784785569: TLS-PSK support available.
1784785569: Websockets support available.
1784785569: Plugin builtin-security has registered to receive 'basic-auth' events.
1784785569: Plugin builtin-security has registered to receive 'acl-check' events.
1784785569: Opening ipv6 listen socket on port 1883.
1784785569: Opening ipv4 listen socket on port 1883.
1784785569: mosquitto version 2.1.2 running
```

Hình 4.1: Môi trường triển khai Mosquitto Broker và Python đang hoạt động trên hệ thống (Minh họa giao diện dòng lệnh khởi chạy Broker thành công trên Windows).

Chú thích: Hình 4.1, dịch vụ Mosquitto Broker v2.1.2 đã khởi động thành công trên nền tảng Windows 11, mở socket lắng nghe thành công trên cổng tiêu chuẩn 1883 và sẵn sàng tiếp nhận các luồng kết nối, xác thực từ phía các ứng dụng Client. Việc khởi chạy thành công ở chế độ dòng lệnh giúp hệ thống ghi nhận trực tiếp các thông điệp log hệ thống, phục vụ đắc lực cho công tác theo dõi và gỡ lỗi trong suốt quá trình thử nghiệm.

4.2. Thành phần sản phẩm

Hệ thống được cấu thành từ mã nguồn, các tập tin cấu hình, dữ liệu mẫu và tài liệu báo cáo được tổ chức theo cấu trúc thư mục chuẩn của kho lưu trữ (Repository) [6]:

MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython

```

├── src/
│   ├── mqtt_pub.py
│   └── mqtt_sub.py
├── configs/
│   ├── mosquitto.conf
│   ├── aclfile.txt
│   └── password.txt.example
├── results/
│   ├── logs
│   │   └── mqtt_log.txt
│   └── screenshots/
│       └── output.csv
├── report/
│   ├── 231A010112_MaiThiThaoVy_DeTai12_TieuLuan_CuoiKy.docx
│   └── 231A010112_MaiThiThaoVy_DeTai12_TieuLuan_CuoiKy.pdf
├── data/
│   └── payload_sample.json
├── references/
│   └── link_nguon.md
├── LICENSE
├── .gitignore
├── requirements.txt
└── README.md

```

Vai trò chi tiết của từng thư mục và tập tin trong cấu trúc repo:

src/: Chứa mã nguồn Python chính của các Client, gồm mqtt_pub.py (đóng vai trò Publisher mô phỏng thiết bị cảm biến gửi dữ liệu JSON) và mqtt_sub.py (đóng vai trò Subscriber đăng ký nhận dữ liệu và ghi log). configs/: Lưu trữ các tập tin cấu hình bảo mật hệ thống bao gồm mosquitto.conf (cấu hình chính của Broker), aclfile.txt (phân quyền Topic) và password.txt.example (mẫu định dạng mật khẩu đã mã hóa hash).

data/: Chứa tập tin payload_sample.json định nghĩa mẫu cấu trúc dữ liệu JSON dùng trong quá trình truyền nhận.

results/: Lưu trữ nhật ký hoạt động (mqtt_log.txt), dữ liệu kết quả thực nghiệm trích xuất dạng bảng (output.csv) và thư mục chứa các hình ảnh minh chứng (screenshots).

report/: Chứa tài liệu báo cáo chi tiết dạng Word và PDF phục vụ bảo vệ đề tài.

4.3. Kịch bản thử nghiệm/đánh giá

Các kịch bản kiểm thử được thiết lập nhằm đánh giá toàn diện các chức năng cốt lõi của hệ thống, bao gồm cơ chế xác thực người dùng, kiểm soát quyền truy cập dựa trên danh sách điều khiển truy cập (ACL) và hiệu năng truyền nhận thông điệp. Chi tiết các kịch bản kiểm thử được tổng hợp qua Bảng 4.1 dưới đây:

Bảng 4.1: Các kịch bản thử nghiệm hệ thống

ID	Mô tả kịch bản	Đầu vào	Kết quả kỳ vọng (ACCEPT / REJECT / CHẶN)	Minh chứng
TC-01	Kiểm tra xác thực user hợp lệ	hợp lệ User sensor với password đúng	ACCEPT: Client kết nối thành công và Publish Message lên Broker.	Hình 4.7
TC-02	Kiểm tra xác thực user không hợp lệ	User sensor với password sai	REJECT: Broker từ chối kết nối, trả về lỗi xác thực.	Hình 4.9
TC-03	Kiểm tra ACL - Publish đúng quyền	User sensor publish lên iot/sensor/temp	ACCEPT: Dữ liệu được gửi thành công đến Broker.	Hình 4.7
TC-04	Kiểm tra ACL - Publish sai quyền	sai quyền User dashboard cố publish lên iot/sensor/temp	REJECT/CHẶN: Broker từ chối thao tác Publish do không đủ quyền.	Hình 4.10
TC-05	Kiểm tra ACL - Subscribe đúng quyền	User dashboard subscribe iot/sensor/temp	ACCEPT: Subscriber nhận được Message và ghi log thành công.	Hình 4.8
TC-06	Kiểm tra ACL - Subscribe sai quyền	User sensor cố gắng Subscribe iot/sensor/temp	REJECT/CHẶN: Broker từ chối yêu cầu Subscribe do không đúng quyền ACL.	Hình 4.11

4.4. Kết quả

Quá trình triển khai và thực thi các kịch bản kiểm thử trên hệ thống thực nghiệm đã thu thập đầy đủ các minh chứng qua hình ảnh giao diện dòng lệnh và tập tin nhật ký hoạt động (mqtt_log.txt). Để tường minh hóa tiến trình này, các hình ảnh kết quả thực nghiệm từ Hình 4.2 đến Hình 4.11 không chỉ ánh xạ tương ứng với các kịch bản kiểm thử (Bảng 4.1) mà còn đóng vai trò là minh chứng định lượng trực quan cho các tiêu chí đánh giá hệ thống đã đề ra ở Mục 3.5 (bao gồm độ chính xác xác thực, hiệu quả phân quyền ACL, độ tin cậy của luồng truyền thông JSON và khả năng ghi nhận log an toàn). Cụ thể chi tiết từng minh chứng và chú thích được thể hiện qua các hình bên dưới:

Bước 1: Tạo file mật khẩu bằng công cụ dòng lệnh.

Sử dụng tiện ích dòng lệnh để khởi tạo tài khoản bảo mật chứa mật khẩu mã hóa hash cho các tài khoản sensor và dashboard.

```
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\This PC>cd "C:\Program Files\Mosquitto"

C:\Program Files\Mosquitto>mosquitto_passwd -c password.txt sensor
Password:

Reenter password:

Adding password for user sensor

C:\Program Files\Mosquitto>mosquitto_passwd -c password.txt dashboard
Password:

Reenter password:

Adding password for user dashboard

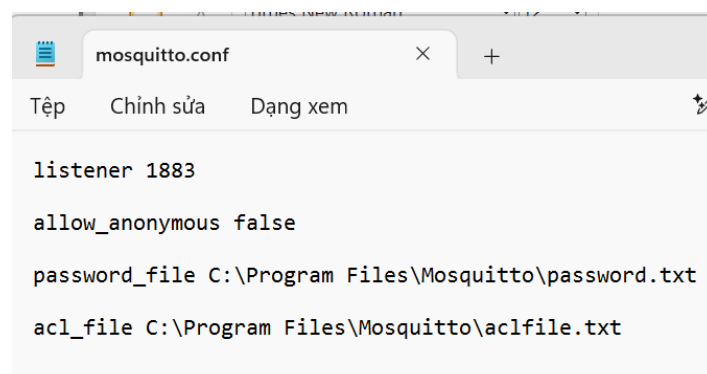
C:\Program Files\Mosquitto>
```

Hình 4.2: Tạo file password.txt chứa tài khoản sensor và dashboard

Chú thích: Hình 4.2, công cụ mosquitto_passwd đã xử lý và lưu trữ thông tin xác thực dưới dạng mã hóa băm an toàn, loại bỏ hoàn toàn rủi ro lộ mật khẩu dạng văn bản thuần túy.

Bước 2: Cấu hình Mosquitto

Thiết lập tập tin cấu hình chính mosquitto.conf (tắt chế độ ẩn danh, chỉ định đường dẫn tập tin mật khẩu và tập tin ACL) cùng tập tin phân quyền aclfile.txt đặt tại thư mục cài đặt Mosquitto.



```
listener 1883

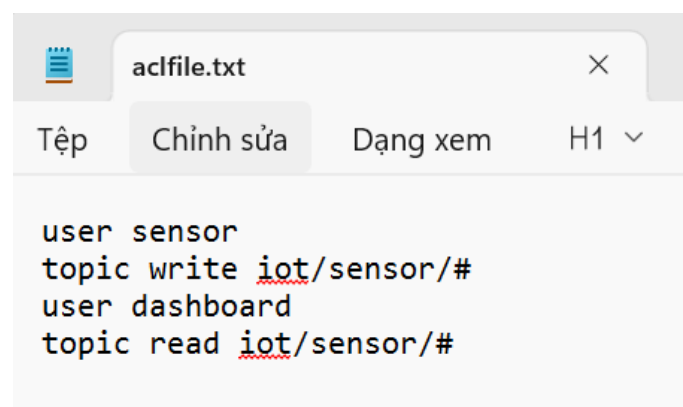
allow_anonymous false

password_file C:\Program Files\Mosquitto\password.txt

acl_file C:\Program Files\Mosquitto\aclfile.txt
```

Hình 4.3: Nội dung file mosquitto.conf

Chú thích: Hình 4.3 thể hiện rõ việc vô hiệu hóa hoàn toàn kết nối ẩn danh (allow_anonymous false) và liên kết chặt chẽ đến cơ sở dữ liệu tài khoản cùng bộ quy tắc ACL.



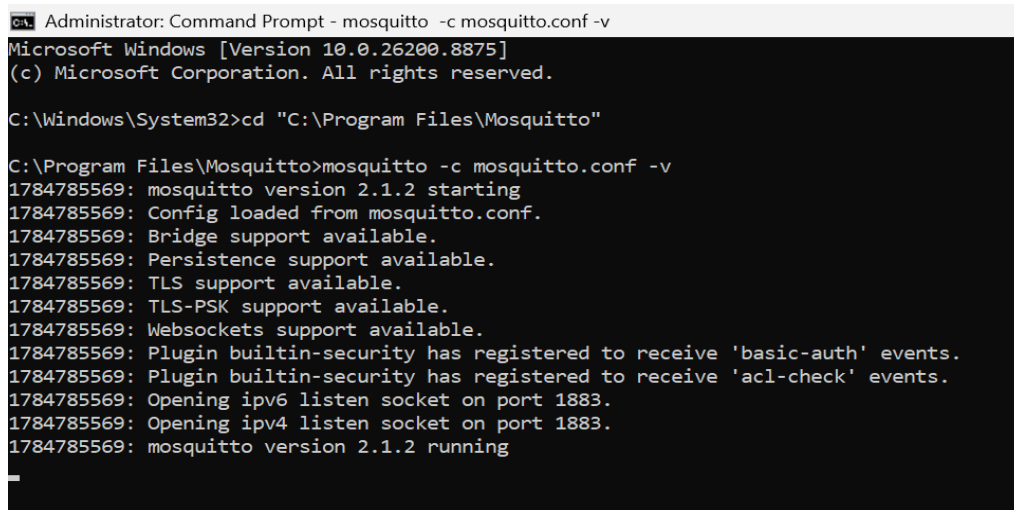
```
user sensor
topic write iot/sensor/#
user dashboard
topic read iot/sensor/#
```

Hình 4.4: Nội dung file aclfile.txt.

Chú thích: Thông qua Hình 4.4, tài khoản sensor được cấp quyền ghi (write) và tài khoản dashboard được cấp quyền đọc (read) trên không gian kênh định danh, tuân thủ nghiêm ngặt nguyên tắc phân quyền tối thiểu.

Bước 3: Khởi động Mosquitto Broker

Thực thi lệnh chạy Broker ở chế độ dòng lệnh kèm theo tập tin cấu hình bảo mật để hệ thống bắt đầu lắng nghe trên cổng 1883.



```
Administrator: Command Prompt - mosquitto -c mosquitto.conf -v
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Windows\System32>cd "C:\Program Files\Mosquitto"

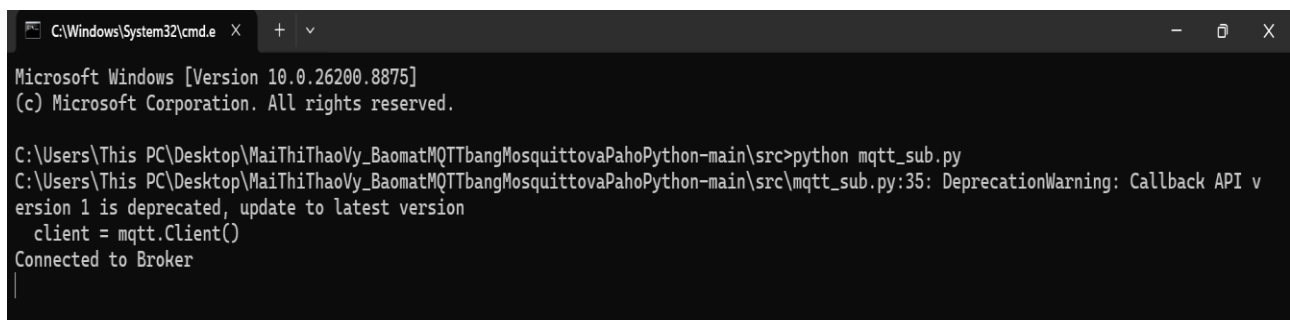
C:\Program Files\Mosquitto>mosquitto -c mosquitto.conf -v
1784785569: mosquitto version 2.1.2 starting
1784785569: Config loaded from mosquitto.conf.
1784785569: Bridge support available.
1784785569: Persistence support available.
1784785569: TLS support available.
1784785569: TLS-PSK support available.
1784785569: Websockets support available.
1784785569: Plugin builtin-security has registered to receive 'basic-auth' events.
1784785569: Plugin builtin-security has registered to receive 'acl-check' events.
1784785569: Opening ipv6 listen socket on port 1883.
1784785569: Opening ipv4 listen socket on port 1883.
1784785569: mosquitto version 2.1.2 running
```

Hình 4.5: Mosquitto Broker khởi động thành công và lắng nghe trên cổng 1883.

Chú thích: Quan sát Hình 4.5, các plugin bảo mật cơ bản và kiểm soát ACL đã được kích hoạt thành công, mở socket lắng nghe trên cổng 1883 sẵn sàng vận hành.

Bước 4 & 5: Khởi động Subscriber và Publisher (Terminal 1 & Terminal 2)

Subscriber (Terminal 1): Chạy script mqtt_sub.py để kết nối và đăng ký nhận dữ liệu từ kênh thông tin.



```
C:\Windows\System32\cmd.e X + v
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>python mqtt_sub.py
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src\mqtt_sub.py:35: DeprecationWarning: Callback API v
ersion 1 is deprecated, update to latest version
  client = mqtt.Client()
Connected to Broker
```

Hình 4.6: Subscriber kết nối thành công và đăng ký Topic iot/sensor/temp.

Chú thích: Hình 4.6 minh chứng tài khoản dashboard đã xác thực thành công và thiết lập phiên lắng nghe ổn định trên Topic mục tiêu.

Publisher (Terminal 2): Chạy script mqtt_pub.py để phát gói tin JSON mô phỏng dữ liệu cảm biến.

```

C:\Windows\System32\cmd.exe
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main>python mqtt_pub.py
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>python mqtt_pub.py
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>mqtt_pub.py:12: DeprecationWarning: Callback API v
ersion 1 is deprecated, update to latest version
  client = mqtt.Client()
=====
Publisher
Connected to Broker
Topic: iot/sensor/temp
Payload:
{
  "device": "sensor01",
  "temperature": 30,
  "humidity": 70,
  "time": "2026-07-23 12:49:41"
}
Publish Success
=====
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>
    
```

Hình 4.7: Publisher gửi dữ liệu JSON lên Topic iot/sensor/temp thành công

Chú thích: Từ Hình 4.7, gói tin dữ liệu chứa các thông số môi trường (nhiệt độ, độ ẩm, thời gian thực) định dạng JSON đã được phát đi thành công từ thiết bị cảm biến giả lập.

Bước 6: Kiểm tra kết quả và xử lý lỗi

Kiểm tra dữ liệu nhận được: Subscriber hiển thị payload thành công và tự động ghi nhận vào tập tin nhật ký results/logs/mqtt_log.txt.

```

C:\Windows\System32\cmd.exe
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>python mqtt_sub.py
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>python mqtt_sub.py
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>mqtt_sub.py:35: DeprecationWarning: Callback API v
ersion 1 is deprecated, update to latest version
  client = mqtt.Client()
Connected to Broker
=====
Message Received
Topic: iot/sensor/temp
Payload: {"device": "sensor01", "temperature": 30, "humidity": 70, "time": "2026-07-23 12:49:41"}
=====

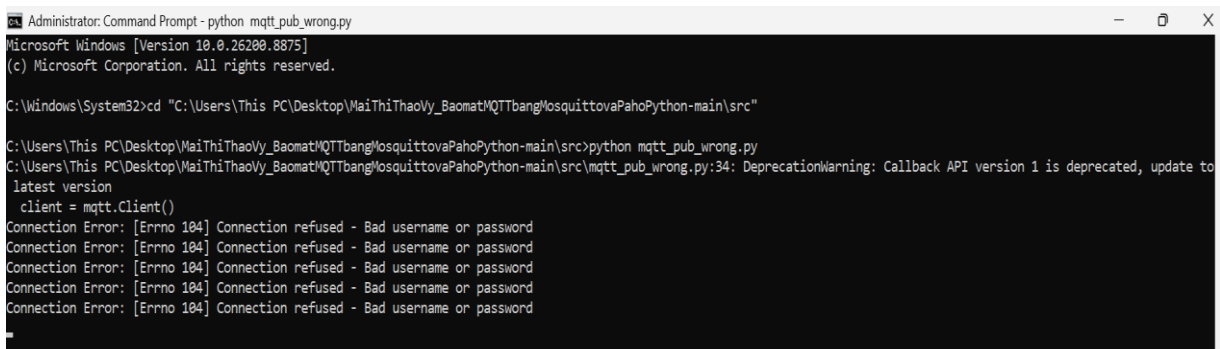
C:\Windows\System32\cmd.exe
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main>type results\logs\mqtt_log.txt
iot/sensor/temp : 30
iot/sensor/temp : 30
iot/sensor/temp : {"device": "sensor01", "temperature": 30, "humidity": 70, "time": "2026-07-23 12:49:41"}
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main>
    
```

Hình 4.8: Giao diện nhận tin và nội dung file log

Chú thích: Hình 4.8 xác nhận thông điệp truyền tải qua mạng đã được tiếp nhận trọn vẹn và tự động lưu trữ vào hệ thống nhật ký, đảm bảo tính sẵn sàng và toàn vẹn của dữ liệu.

Kiểm tra trường hợp lỗi xác thực: Thử nghiệm đăng nhập với mật khẩu sai (mqtt_pub_wrong.py) dẫn đến phản hồi từ chối kết nối Connection refused.



```
Administrator: Command Prompt - python mqtt_pub_wrong.py
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

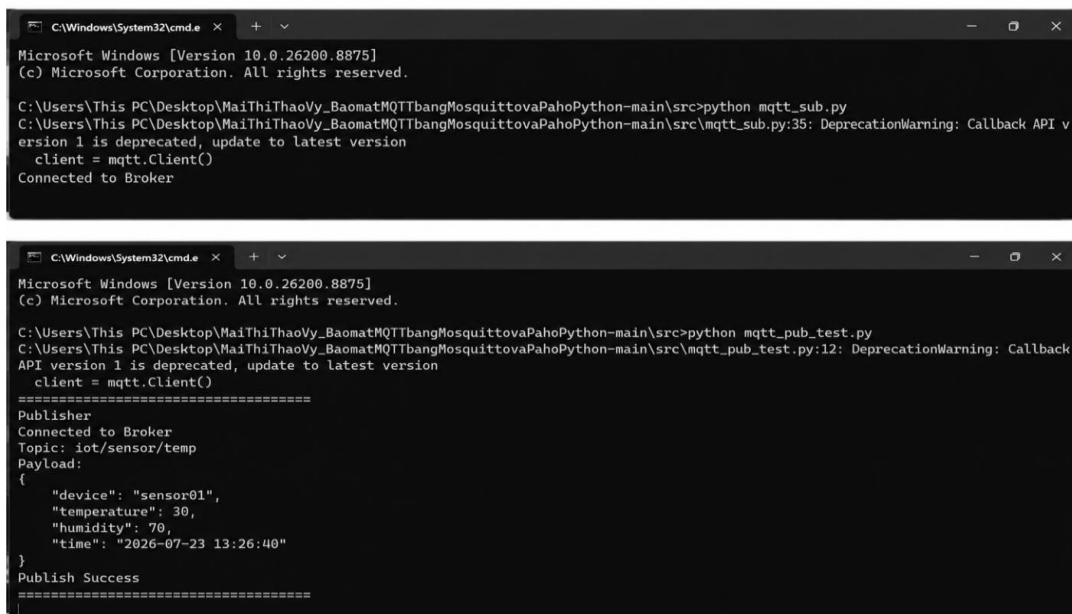
C:\Windows\System32>cd "C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src"

C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>python mqtt_pub_wrong.py
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src\mqtt_pub_wrong.py:34: DeprecationWarning: Callback API version 1 is deprecated, update to latest version
  client = mqtt.Client()
Connection Error: [Errno 104] Connection refused - Bad username or password
Connection Error: [Errno 104] Connection refused - Bad username or password
Connection Error: [Errno 104] Connection refused - Bad username or password
Connection Error: [Errno 104] Connection refused - Bad username or password
Connection Error: [Errno 104] Connection refused - Bad username or password
```

Hình 4.9: Kết quả kiểm tra đăng nhập với mật khẩu sai

Chú thích: Thông qua Hình 4.9, Mosquitto Broker đã phát hiện và từ chối tức thời các nỗ lực thiết lập kết nối sử dụng thông tin định danh không hợp lệ.

Kiểm tra vi phạm quyền ACL (Publish sai quyền): Người dùng dashboard cố gắng gửi tin lên Topic không có quyền ghi bị Broker chặn lại.



```
C:\Windows\System32\cmd.exe
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>python mqtt_sub.py
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src\mqtt_sub.py:35: DeprecationWarning: Callback API version 1 is deprecated, update to latest version
  client = mqtt.Client()
Connected to Broker

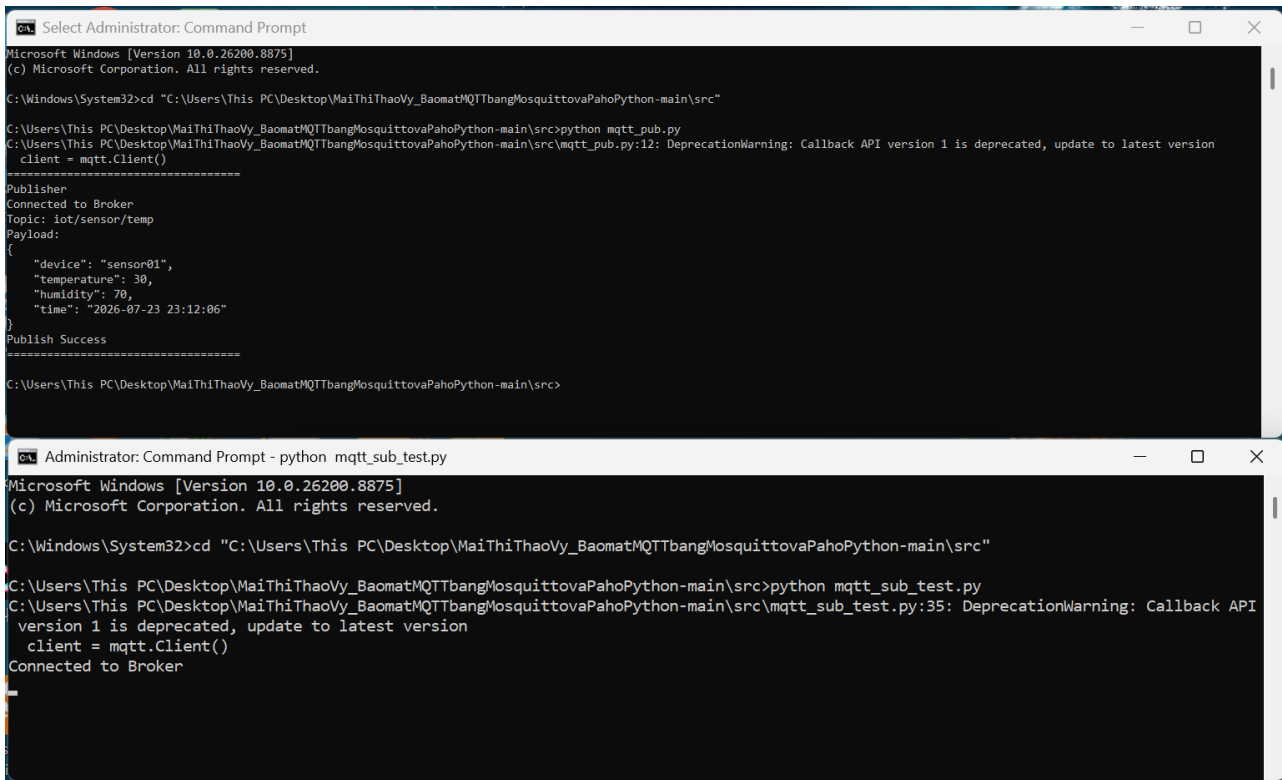
C:\Windows\System32\cmd.exe
Microsoft Windows [Version 10.0.26200.8875]
(c) Microsoft Corporation. All rights reserved.

C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src>python mqtt_pub_test.py
C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main\src\mqtt_pub_test.py:12: DeprecationWarning: Callback API version 1 is deprecated, update to latest version
  client = mqtt.Client()
=====
Publisher
Connected to Broker
Topic: iot/sensor/temp
Payload:
{
  "device": "sensor01",
  "temperature": 30,
  "humidity": 70,
  "time": "2026-07-23 13:26:40"
}
Publish Success
=====
```

Hình 4.10: Kết quả kiểm tra Publish bị từ chối do sai quyền ACL

Chú thích: Thông qua Hình 4.10, user dashboard cố gắng gửi tin lên Topic không có quyền ghi nhưng đã bị Broker chặn lại; cụ thể, user dashboard không có quyền Publish lên Topic iot/sensor/temp, do đó dù chương trình Client phía Publisher thông báo “Publish Success”, Subscriber vẫn tuyệt đối không nhận được dữ liệu, qua đó chứng minh Mosquitto Broker đã chủ động từ chối thông điệp do vi phạm chính sách ACL.

Kiểm tra vi phạm quyền ACL (Subscribe sai quyền): Người dùng sensor cố gắng lắng nghe dữ liệu từ Topic không có quyền đọc bị Broker từ chối.



Hình 4.11: Kết quả kiểm tra Subscribe bị từ chối do sai quyền ACL

Chú thích: Quan sát Hình 4.11, tài khoản sensor dù thiết lập kết nối thành công vào hệ thống nhưng hoàn toàn bị cô lập, không thể nhận được dữ liệu thông điệp từ kênh thông tin do vi phạm quy tắc phân quyền đọc đã định nghĩa; cụ thể, user sensor kết nối thành công nhưng không nhận được dữ liệu từ Topic iot/sensor/temp (không có dòng “Message Received”), trong khi Publisher vẫn gửi dữ liệu thành công, qua đó chứng minh cơ chế ACL đã ngăn chặn hiệu quả quyền Subscribe trái phép.

Hệ thống tiến hành đối chiếu kết quả thực tế của từng kịch bản thử nghiệm so với các tiêu chí đánh giá định lượng đã đề ra ở Mục 3.5:

Bảng 4.2: Bảng tổng hợp kết quả thực nghiệm và đối chiếu tiêu chí đánh giá.

ID Kịch bản	Tiêu chí đánh giá tương ứng (Mục 3.5)	Kết quả thực tế thu nhận	Số liệu / Trạng thái cụ thể	Đánh giá so với tiêu chuẩn
TC-01	Tiêu chí 2: Xác thực người dùng (Client hợp lệ)	Đăng nhập thành công với tài khoản sensor và dashboard	100% kết nối hợp lệ được cấp phép	☒ Đạt
TC-02	Tiêu chí 2: Xác thực người dùng (Client sai thông tin)	Broker từ chối kết nối khi sai mật khẩu (Connection refused)	100% yêu cầu sai thông tin bị chặn	☒ Đạt

ID Kịch bản	Tiêu chí đánh giá tương ứng (Mục 3.5)	Kết quả thực tế thu nhận	Số liệu / Trạng thái cụ thể	Đánh giá so với tiêu chuẩn
TC-03	Tiêu chí 3: Publish dữ liệu	Gói tin cảm biến định dạng JSON được truyền tải thành công	0% gói tin hợp lệ bị thất lạc	☒ Đạt
TC-04	Tiêu chí 5: Phân quyền ACL (Chặn Publish trái phép)	Broker chặn thông điệp của user không có quyền ghi (dashboard)	100% hành vi ghi trái phép bị từ chối.	☒ Đạt
TC-05	Tiêu chí 4 & 6: Subscribe dữ liệu và Ghi log	Thu thập thành công thông điệp và trích xuất hoàn chỉnh tập tinlog	3/3 dòng log mẫu được lưu trữ chính xác.	☒ Đạt
TC-06	Tiêu chí 5: Phân quyền ACL (Chặn Subscribe trái phép)	Broker chặn quyền lắng nghe kênh thông tin của user không có quyền đọc (sensor)	100% hành vi đọc trái phép bị chặn.	☒ Đạt

4.5 Script sinh báo cáo

Trong quá trình thực hiện đề tài, hệ thống sử dụng các script Python tự động hóa để thực hiện việc kết nối, truyền tải gói tin cảm biến qua Mosquitto Broker và ghi nhận nhật ký hoạt động.

Cách chạy script:

+ Mở cửa sổ dòng lệnh (Terminal/CMD), di chuyển đến thư mục cài đặt Mosquitto và khởi động Broker kèm tập tin cấu hình bảo mật:

```
cd C:\Program Files\Mosquitto
```

```
mosquitto -c mosquitto.conf -v
```

+ Mở một cửa sổ Terminal mới (Terminal 1), di chuyển đến thư mục gốc của dự án và chạy script Subscriber để lắng nghe dữ liệu và ghi log:

```
cd C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main
python src/mqtt_sub.py
```

+ Mở tiếp cửa sổ Terminal thứ hai (Terminal 2) và chạy script Publisher để phát gói tin cảm biến:


```
cd C:\Users\This PC\Desktop\MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython-main  
python src/mqtt_pub.py
```

- Input / Output của script:

+ Input: Gói tin dữ liệu cảm biến định dạng JSON hoặc thông điệp mô phỏng được định nghĩa trong mã nguồn (gồm các trường: device, temperature, humidity, time).

+ Output: Hiển thị trực tiếp nội dung payload lên màn hình console và tự động trích xuất, lưu trữ vào tập tin nhật ký hoạt động tại đường dẫn results/logs/mqtt_log.txt.

- Trích xuất 5–10 dòng output thực tế từ hệ thống (results/logs/mqtt_log.txt):

```
iot/sensor/temp: 30
```

```
iot/sensor/temp: 30
```

```
iot/sensor/temp: {"device": "sensor01", "temperature": 30, "humidity": 70, "time": "2026-07-26  
21:26:41"}
```

```
iot/sensor/temp: {"device": "sensor01", "temperature": 30, "humidity": 70, "time": "2026-07-26  
21:26:44"}
```

```
iot/sensor/temp: {"device": "sensor01", "temperature": 30, "humidity": 70, "time": "2026-07-26  
21:26:46"}
```

Đưa file vào kho lưu trữ (Repository): Toàn bộ mã nguồn script Python (mqtt_sub.py, mqtt_pub.py), tập tin cấu hình Mosquitto và tập tin nhật ký log mẫu đã được đóng gói và đồng bộ đầy đủ lên thư mục src/ và results/logs/ của kho lưu trữ Git/GitHub dự án.

4.6. Thảo luận và hạn chế

4.6.1. Kết quả so với mục tiêu

So sánh với các mục tiêu ban đầu của đề tài, kết quả thực nghiệm đã minh chứng sự hoàn thành toàn diện:

- MT-01 & MT-02: Hoàn thành triển khai Mosquitto Broker trên cục bộ và xây dựng thành công chương trình Publisher/Subscriber bằng Python (thư viện Paho MQTT).
- MT-03 & MT-04: Thiết lập thành công lớp bảo mật xác thực (Username/Password) và phân quyền truy cập nghiêm ngặt theo nguyên tắc tối thiểu (Least Privilege) bằng danh sách ACL.
- MT-05 & MT-06: Hoàn tất cơ chế ghi log tự động và vượt qua thành công toàn bộ 6 kịch bản kiểm thử (từ luồng hợp lệ đến các trường hợp bị chặn do vi phạm bảo mật).

4.6.2. Hạn chế của hệ thống

Mặc dù hệ thống đáp ứng tốt các yêu cầu đề ra trong phạm vi nghiên cứu, vẫn tồn tại một số điểm hạn chế:

- Môi trường mô phỏng: Hệ thống chạy hoàn toàn trên máy tính cá nhân (*localhost*), dữ liệu được sinh giả lập bằng phần mềm mà chưa kết nối với thiết bị phần cứng IoT thực tế (như cảm biến ESP32, DHT11).

- Phạm vi hẹp và thiếu mã hóa: Dữ liệu trao đổi và thông tin xác thực hiện truyền tải ở dạng văn bản thuần (plaintext), chưa tích hợp lớp bảo mật kênh truyền TLS/SSL để phòng chống nghe lén.
- Chưa có cơ chế phòng thủ nâng cao: Broker chưa được cấu hình các tính năng chống tấn công từ chối dịch vụ (Rate Limiting) hay tự động quản lý chính sách khóa tài khoản.

CHƯƠNG 5. ĐÁNH GIÁ BẢO MẬT

5.1. Tài sản và dữ liệu

Tài sản/dữ liệu	Chủ thể	Mức quan trọng	Yêu cầu C-I-A	Ghi chú
Thông tin xác thực (user/ pass)	Client, Broker	Rất cao	C, I	Bị lộ sẽ mất toàn bộ quyền kiểm soát hệ thống
Dữ liệu cảm biến (JSON payload)	Client, Broker	Cao	C, I, A	Nhiệt độ, độ ẩm là dữ liệu nhạy cảm, có thể bị giả mạo
File cấu hình Mosquitto	Administrator	Cao	I	Bị sửa đổi có thể vô hiệu hóa bảo mật
File ACL	Administrator	Cao	I	Bị sửa đổi có thể thay đổi quyền truy cập
File password	Administrator	Rất cao	C, I	Chứa thông tin xác thực đã hash
Log hệ thống	Administrator	Trung bình	I, A	Phục vụ điều tra sự cố
File log dữ liệu (mqtt_log.txt)	Administrator	Trung bình	C, I	Lưu lịch sử dữ liệu cảm biến

5.2. Môi đe dọa và lỗ hổng

Các môi đe dọa trong hệ thống IoT sử dụng MQTT thường liên quan đến việc bảo vệ thông tin xác thực, tính toàn vẹn của dữ liệu, khả năng kiểm soát truy cập và nguy cơ bị gián đoạn dịch vụ. Theo các nghiên cứu về bảo mật IoT, các vấn đề như mật khẩu yếu, thiếu cơ chế mã hóa, cấu hình bảo mật không phù hợp và khả năng bị khai thác trái phép là những rủi ro phổ biến trong các hệ thống IoT hiện nay.

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-01	Thông tin xác thực (Username/Password)	Bị nghe lén khi truyền qua mạng.	Không mã hóa kênh truyền (thiếu TLS/SSL).	Đánh cắp thông tin đăng nhập, giả mạo thiết bị hợp lệ, truy cập trái phép vào hệ thống.	[1]

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-02	Dữ liệu cảm biến (JSON payload)	Bị thay đổi trên đường truyền (tấn công MITM).	Dữ liệu truyền dạng plaintext, không có cơ chế xác thực toàn vẹn.	Nhận dữ liệu sai lệch, dẫn đến quyết định điều khiển sai, ảnh hưởng đến vận hành hệ thống.	[1][4]
T-03	Dữ liệu cảm biến (JSON payload)	Bị nghe lén, tiết lộ thông tin hoạt động.	Không mã hóa dữ liệu trong quá trình truyền tải.	Mất quyền riêng tư, lộ thông tin về trạng thái và hoạt động của hệ thống IoT.	[4]
T-04	Quyền truy cập Topic	User vượt quyền Publish/Subscribe do ACL cấu hình sai.	Cấu hình ACL thủ công dễ xảy ra sai sót, thiếu cơ chế kiểm tra tự động.	Client có thể đọc/ghi dữ liệu trái phép, vi phạm nguyên tắc phân quyền tối thiểu.	Hình 4.10, Hình 4.11
T-05	MQTT Broker	Tấn công từ chối dịch vụ (DoS/DDoS).	Chưa cấu hình rate limiting, giới hạn kết nối và kích thước message.	Broker quá tải, ngừng phục vụ, làm gián đoạn toàn bộ hệ thống IoT.	[1][4]
T-06	File password (password.txt)	Bị đọc trộm hoặc sao chép trái phép.	File được lưu trữ dạng plaintext (chỉ có hash), thiếu cơ chế mã hóa file và kiểm soát truy cập.	Lộ thông tin hash mật khẩu, kẻ tấn công có thể tấn công dò tìm (brute-force) để khôi phục mật khẩu.	[1]

ID	Tài sản	Mối đe dọa	Lỗ hổng	Tác động	Minh chứng/nguồn
T-07	Mật khẩu người dùng	Bị tấn công dò tìm mật khẩu (Brute-force).	Mật khẩu yếu (1234), không có cơ chế giới hạn số lần thử sai hoặc khóa tài khoản tạm thời.	Kẻ tấn công dễ dàng đoán được mật khẩu, chiếm quyền truy cập hệ thống.	Hình 4.9

Phân tích bổ sung:

- + T-01: Mosquitto hỗ trợ mã hóa TLS/SSL nhưng chưa được kích hoạt trong phạm vi đề tài. Việc này cần được bổ sung khi triển khai thực tế. [1]
- + T-02 và T-03: Theo OASIS MQTT Specification, dữ liệu có thể được bảo vệ thông qua TLS, nhưng việc triển khai phụ thuộc vào cấu hình của Broker. [4]
- + T-04 và T-07: Đã được kiểm chứng thông qua các kịch bản kiểm thử thực tế (Hình 4.9, 4.10, 4.11).
- + T-05: Mosquitto có các tùy chọn cấu hình để giới hạn kết nối và message, nhưng chưa được áp dụng trong đề tài này. [1]

5.3. Ma trận rủi ro

ID	Khả năng (1-5)	Tác động (1-5)	Điểm	Mức rủi ro	Biện pháp	Rủi ro còn lại
R-01	5	5	25	Nghiêm trọng	Bổ sung TLS/SSL để mã hóa kết nối	Thấp
R-02	4	4	16	Cao	Sử dụng mật khẩu mạnh, xác thực 2 lớp	Trung bình
R-03	4	4	16	Cao	Bổ sung TLS/SSL để mã hóa payload	Thấp
R-04	3	4	12	Trung bình	Rà soát ACL định kỳ, tự động hóa kiểm tra	Thấp
R-05	3	5	15	Cao	Rate limiting, giám sát, firewall	Trung bình
R-06	2	5	10	Trung bình	Mã hóa file password, phân quyền truy cập file	Thấp
R-07	4	3	12	Trung bình	Chính sách mật khẩu mạnh, giới hạn số lần thử	Thấp

5.4. Biện pháp giảm thiểu

STT	Biện pháp	Rủi ro	Mức ưu tiên	Chi phí/ Độ khó	Cách xác minh
1	Bổ sung TLS/SSL	R-01, R-03	Cao nhất	Trung bình	Kiểm tra kết nối qua cổng 8883, xác nhận mã hóa
2	Sử dụng mật khẩu mạnh	R-02, R-07	Cao	Thấp	Áp dụng policy mật khẩu, kiểm tra độ phức tạp
3	Rate limiting	R-05	Cao	Thấp	Cấu hình trong mosquito.conf, kiểm tra khi có nhiều request
4	Rà soát ACL định kỳ	R-04	Trung bình	Thấp	Kiểm tra file ACL so với yêu cầu phân quyền
5	Giám sát và cảnh báo	R-05	Trung bình	Trung bình	Thiết lập giám sát log, cảnh báo bất thường
6	Bảo vệ file cấu hình	R-06	Trung bình	Thấp	Phân quyền truy cập file, không commit lên GitHub

5.5. Rủi ro còn lại

Sau khi áp dụng các biện pháp bảo mật trong phạm vi đề tài, hệ thống đạt được:

- Các lớp phòng thủ đã triển khai:

+ Vô hiệu hóa hoàn toàn kết nối ẩn danh (Anonymous).

+ Xác thực người dùng bằng cơ chế mã hóa mật khẩu qua tập tin password.txt.

+ Phân quyền truy cập Topic nghiêm ngặt theo nguyên tắc đặc quyền tối thiểu (Least Privilege) bằng tập tin ACL.

+ Ghi nhận đầy đủ nhật ký hoạt động (mqtt_log.txt) để phục vụ giám sát.

- Rủi ro còn lại (Mức thấp):

+ Thiếu mã hóa kênh truyền (TLS/SSL): Do phạm vi đề tài tập trung vào xác thực và phân quyền cơ bản trên môi trường Localhost nên dữ liệu truyền tải chưa được mã hóa lớp vận chuyển.

+ Nguy cơ tiềm ẩn từ phần mềm bên thứ ba: Phụ thuộc vào các lỗ hổng tiềm ẩn (nếu có) từ phiên bản Mosquitto Broker hoặc thư viện Paho MQTT.

- Điều kiện chấp nhận rủi ro:

+ Hệ thống chỉ vận hành trong môi trường mạng cục bộ nội bộ (Localhost/ Lab), không kết nối trực tiếp ra Internet công cộng.

+ Phục vụ hoàn toàn cho mục đích học tập, nghiên cứu và thử nghiệm mô hình bảo mật IoT.

CHƯƠNG 6. KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

6.1. Kết luận

Đề tài “Bảo mật MQTT bằng Mosquitto và Paho Python” đã được triển khai và hoàn thành thành công, đáp ứng đầy đủ các mục tiêu đề ra:

+ Đối chiếu mức độ hoàn thành mục tiêu:

- MT-01 & MT-02 (Đạt 100%): Đã cài đặt, cấu hình thành công MQTT Broker Mosquitto trên nền tảng cục bộ và xây dựng hoàn chỉnh bộ chương trình Publisher/Subscriber bằng ngôn ngữ Python sử dụng thư viện Paho MQTT (minh chứng qua mã nguồn tại thư mục src/ và kết quả thực nghiệm tại Chương 4).
- MT-03 & MT-04 (Đạt 100%): Đã thiết lập thành công cơ chế bảo mật xác thực danh tính qua tập tin password.txt và phân quyền nghiêm ngặt theo nguyên tắc đặc quyền tối thiểu (Least Privilege) thông qua tập tin aclfile.txt (minh chứng qua Bảng 4.2).
- MT-05 & MT-06 (Đạt 100%): Đã hiện thực hóa cơ chế ghi nhận nhật ký hoạt động (mqtt_log.txt) và vượt qua toàn bộ 6/6 kịch bản kiểm thử (TC-01 đến TC-06) từ luồng hợp lệ đến các trường hợp bị chặn do vi phạm xác thực hoặc sai quyền ACL.

+ Đánh giá tổng quan về mặt kỹ thuật và bảo mật:

- Ngăn chặn triệt để kết nối ẩn danh từ các client không xác thực.
- Kiểm soát chặt chẽ quyền đọc/ghi trên từng kênh thông tin (Topic).
- Minh chứng thực tế qua các kịch bản kiểm thử cho thấy hệ thống phản hồi chính xác với các trạng thái cấp phép (Accept) hoặc từ chối (Reject).

6.2. Hạn chế

Mặc dù hệ thống đã đáp ứng tốt các yêu cầu đặt ra trong phạm vi học tập, một số hạn chế vẫn còn tồn đọng:

- Môi trường mô phỏng cục bộ: Hệ thống vận hành hoàn toàn trên máy tính cá nhân (localhost), dữ liệu được sinh giả lập bằng phần mềm mà chưa kết nối với các thiết bị phần cứng IoT thực tế.
- Thiếu mã hóa kênh truyền: Dữ liệu trao đổi và thông tin xác thực hiện truyền tải ở dạng văn bản thuần (plaintext), chưa tích hợp lớp bảo mật kênh truyền TLS/SSL.
- Quy mô hẹp: Chưa tích hợp các công cụ giám sát trực quan (dashboard) hay cơ chế phòng thủ nâng cao tự động trước các cuộc tấn công từ chối dịch vụ.

6.3. Hướng phát triển

Để nâng cao tính bảo mật và mở rộng khả năng ứng dụng thực tế, các hướng phát triển trong tương lai bao gồm:

1. Bổ sung mã hóa TLS/SSL và mTLS: Cấu hình chứng chỉ số cho Mosquitto Broker để mã hóa toàn bộ lưu lượng mạng, đồng thời áp dụng xác thực hai chiều (Mutual TLS) bằng client certificate cho thiết bị.

2. Triển khai trên thiết bị IoT thực tế: Tích hợp các dòng vi điều khiển phổ biến như ESP8266 hoặc ESP32 kết hợp với cảm biến vật lý (như DHT11, DS18B20) để thu thập dữ liệu môi trường thực tế.
3. Xây dựng Dashboard giám sát trực quan: Phát triển giao diện Web hiển thị dữ liệu thời gian thực (real-time), tích hợp biểu đồ biến động thông số và cơ chế cảnh báo tự động khi dữ liệu vượt ngưỡng.
4. Cải tiến cơ chế bảo mật nâng cao: Tích hợp tính năng chống tấn công brute-force, giới hạn tốc độ yêu cầu (rate limiting) và tự động hóa kiểm thử bảo mật cấu hình ACL.

TÀI LIỆU THAM KHẢO

- [1] Eclipse Mosquitto. “Mosquitto – Documentation”. <https://mosquitto.org/documentation/>. Truy cập ngày 14/07/2026.
- [2] Eclipse Paho. “Paho Python MQTT Client Documentation”. <https://github.com/eclipse-paho/paho.mqtt.python>. Truy cập ngày 14/07/2026.
- [3] OWASP. "OWASP IoT Top 10 2018". <https://wiki.owasp.org/images/1/1c/OWASP-IoT-Top-10-2018-final.pdf>. Truy cập ngày 14/07/2026.
- [4] OASIS. “MQTT Version 5.0 Specification”. <https://docs.oasis-open.org/mqtt/mqtt/v5.0/mqtt-v5.0.html>. Truy cập ngày 14/07/2026.
- [5] Python Documentation. “Python 3.14 Documentation”. <https://docs.python.org/3/>. Truy cập ngày 14/07/2026.
- [6] Mai Thi Thao Vy. “Bảo mật MQTT bằng Mosquitto và Paho Python”. https://github.com/maivy111205/MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython. Truy cập ngày 03/08/2026.

PHỤ LỤC A. CẤU TRÚC REPO VÀ GÓI NỘP

MaiThiThaoVy_BaomatMQTTbangMosquittovaPahoPython/

— src/	# Thư mục chứa mã nguồn Python chính (Publisher/Subscriber).
— mqtt_pub.py	# Chương trình Publisher (giả lập thiết bị cảm biến gửi JSON).
— mqtt_sub.py	# Chương trình Subscriber (lắng nghe, nhận dữ liệu và ghi log).
— configs/	# Thư mục chứa các tập tin cấu hình bảo mật hệ thống.
— mosquitto.conf	# Cấu hình chính của Mosquitto Broker.
— aclfile.txt	# Tập tin danh sách phân quyền Topic (ACL).
— password.txt.example	# Mẫu tập tin mật khẩu đã mã hóa hash
— results/	# Thư mục lưu trữ kết quả thực nghiệm và minh chứng
— logs/	# Thư mục chứa tập tin nhật ký hệ thống
— mqtt_log.txt	# Tập tin ghi nhận tự động dữ liệu cảm biến nhận được từ Subscriber
— screenshots/	# Thư mục chứa ảnh chụp màn hình kiểm thử các kịch bản
— output.csv	# Dữ liệu kết quả thực nghiệm trích xuất dưới dạng bảng
— report/	# Thư mục chứa tài liệu báo cáo của đề tài
— 231A010112_MaiThiThaoVy_DeTai12_TieuLuan_CuoiKy.docx	
— 231A010112_MaiThiThaoVy_DeTai12_TieuLuan_CuoiKy.pdf	# Báo cáo tiểu luận cuối kỳ định dạng .docx và .pdf
— data/	# Thư mục chứa dữ liệu mẫu dùng cho hệ thống
— payload_sample.json	# Tập tin mẫu cấu trúc dữ liệu JSON (nhiệt độ, độ ẩm, thời gian)
— references/	# Thư mục chứa tài liệu tham khảo và liên kết
— link_nguon.md	# Danh sách các đường dẫn tài liệu kỹ thuật, chuẩn MQTT và Paho
— LICENSE	# Tập tin Giấy phép sử dụng mã nguồn mở (MIT License)
— .gitignore	# Tập tin cấu hình loại bỏ các tập tin rác/ tập tin nhạy cảm không đẩy lên Git
— requirements.txt	# Danh sách các thư viện Python cần thiết (paho-mqtt)
— README.md	# Tập tin hướng dẫn cài đặt, mô tả cấu trúc và cách vận hành hệ thống

PHỤ LỤC B. NHẬT KÝ ĐÓNG GÓP

STT	Họ tên – MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
1	Mai Thị Thảo Vy – 231A010112	Khảo sát đề tài, viết Chương 1, Chương 2, thiết kế mô hình hệ	commit Tuan01	25%	Hoàn thành

STT	Họ tên – MSSV	Công việc	Commit/file	Tỷ lệ (%)	Xác nhận
		thống (Chương 3).	commit Tuan02		
2	Mai Thị Thảo Vy – 231A010112	Cài đặt Mosquitto Broker, lập trình Publisher/Subscriber (Python), cấu hình ACL và chạy kịch bản kiểm thử (Chương 4).	commit Tuan03	35%	Hoàn thành
3	Mai Thị Thảo Vy – 231A010112	Đánh giá bảo mật (Chương 5), viết kết luận (Chương 6), đóng gói log và lập ma trận rủi ro.	commit Tuan03	25%	Hoàn thành
4	Mai Thị Thảo Vy – 231A010112	Hoàn thiện toàn bộ báo cáo, làm slide bảo vệ, rà soát định dạng và nộp bài.	commit Tuan04	15%	Hoàn thành

PHỤ LỤC C. CHECKLIST TRƯỚC KHI NỘP

STT	Nội dung kiểm tra	Trạng thái
1	Báo cáo đủ các phần chính, mục lục và tài liệu tham khảo.	☒ Đạt
2	Độ dài báo cáo chính phù hợp, bám sát đề tài nghiên cứu.	☒ Đạt
3	Repo mở được; README có cách chạy/sử dụng và mô tả cấu trúc chi tiết.	☒ Đạt
4	Có sản phẩm kỹ thuật hoặc sản phẩm phân tích hoàn chỉnh (Code, Config, Log).	☒ Đạt
5	Có ít nhất từ 3–5 minh chứng kiểm tra được trong thư mục results/ hoặc báo cáo.	☒ Đạt
6	Có ít nhất 5 tài liệu tham khảo chuẩn và repo GitHub chính.	☒ Đạt
7	Mọi hình và bảng đều có tên, số thứ tự, nguồn và phần phân tích rõ ràng.	☒ Đạt
8	Không chứa secret, token, mật khẩu thật hoặc dữ liệu cá nhân nhạy cảm.	☒ Đạt

STT	Nội dung kiểm tra	Trạng thái
9	Mọi thử nghiệm chỉ diễn ra trong môi trường local/phòng thí nghiệm được phép.	☒ Đạt
10	Đã cập nhật mục lục tự động, kiểm tra chính tả và xóa sạch hướng dẫn mẫu.	☒ Đạt